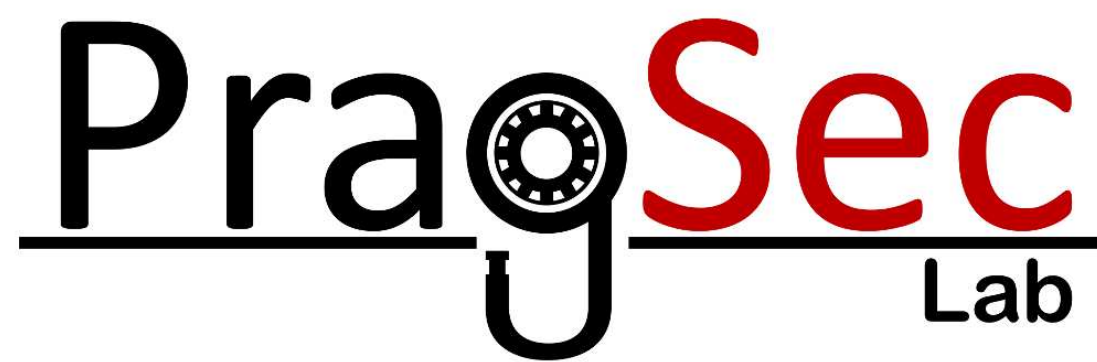


Catching Transparent Phish: Analyzing and Detecting MITM Phishing Toolkits

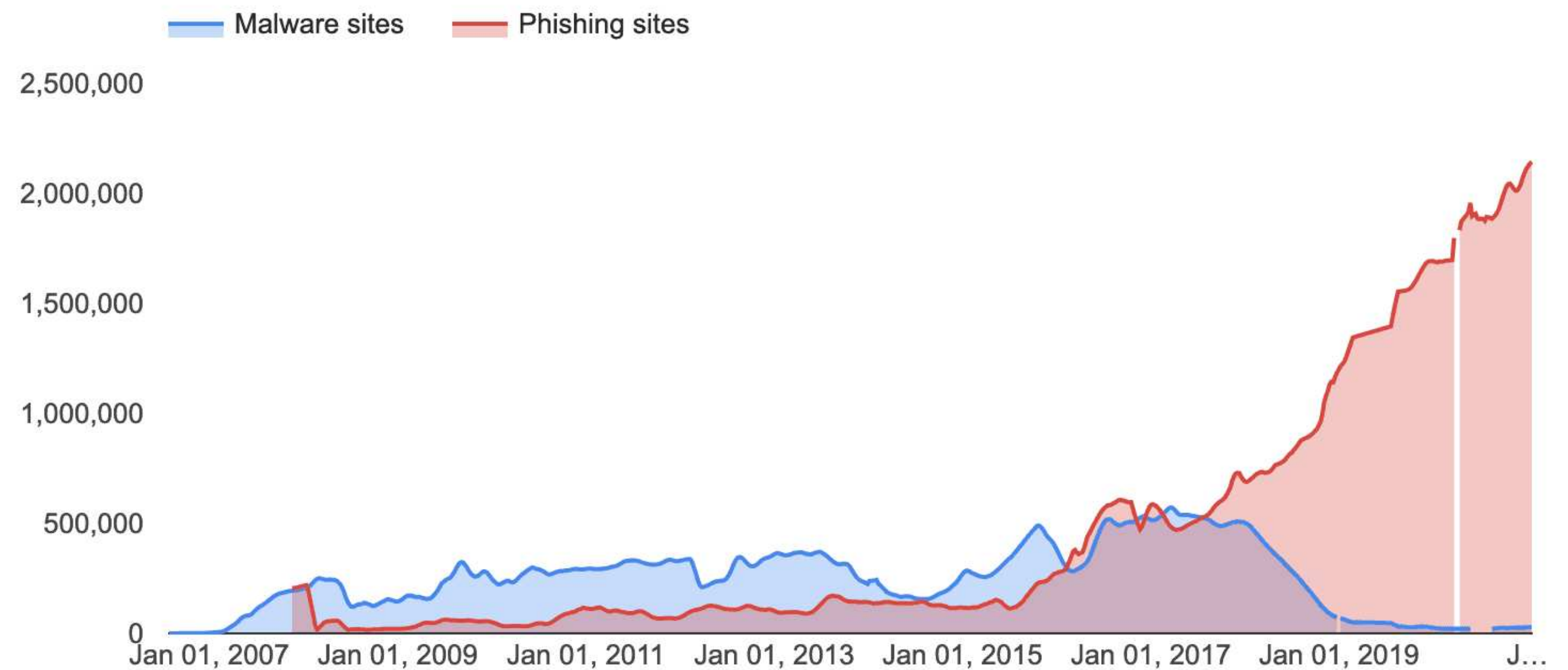
Brian Kondracki, Babak Amin Azad, Oleksii Starov and Nick Nikiforakis



The Value of Stolen Data

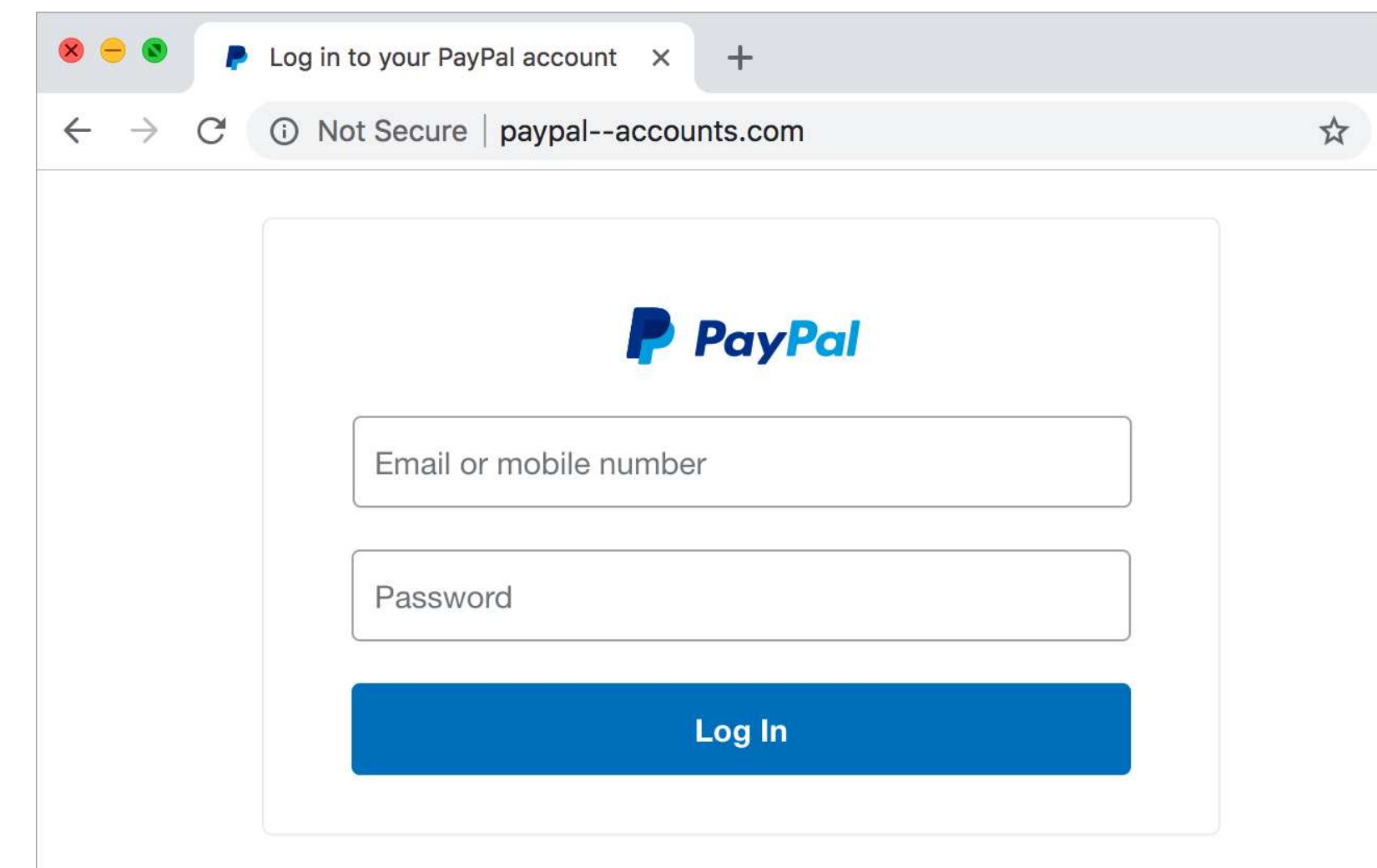
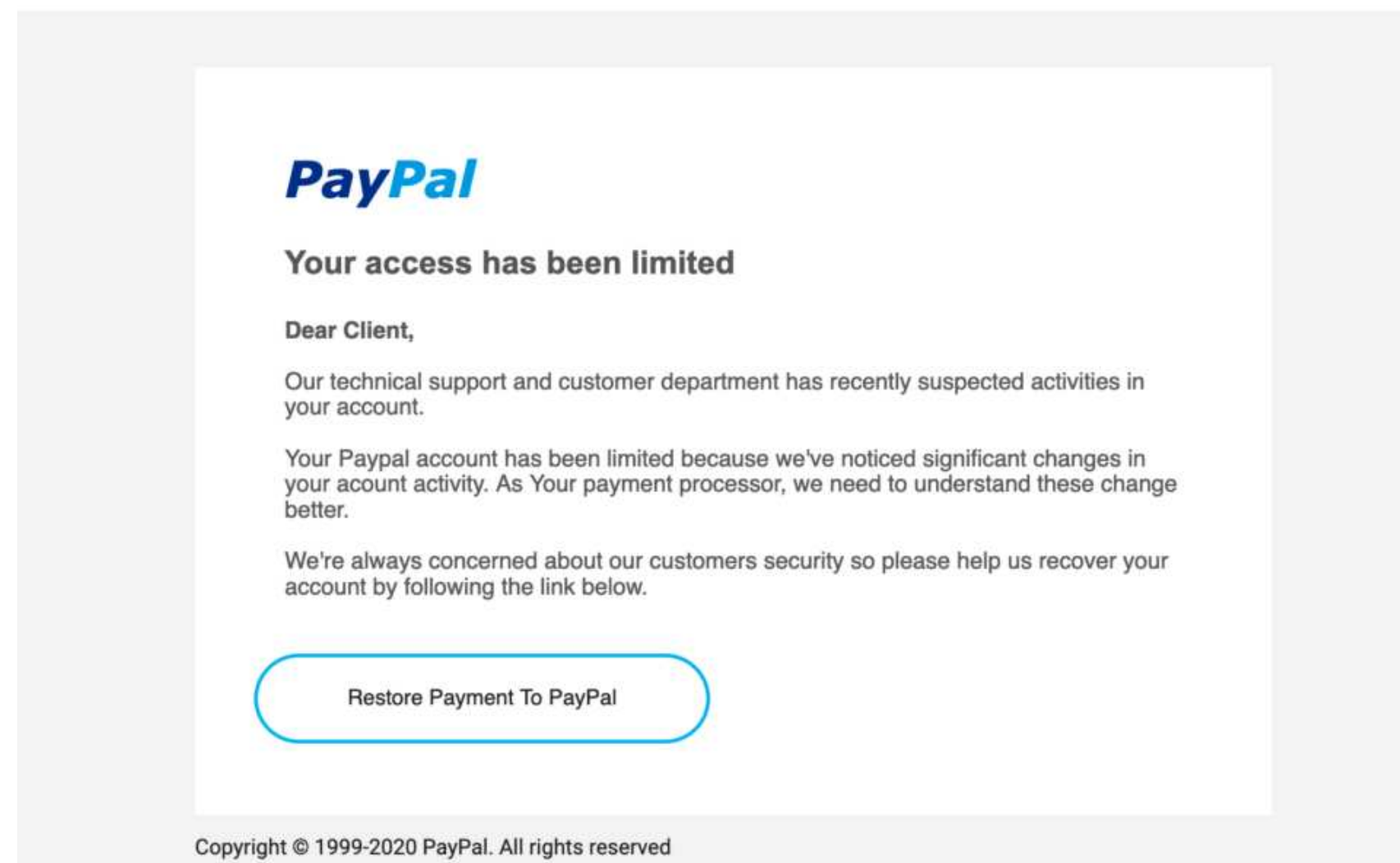
 Spotify Account \$2.75	 Hulu Account \$2.75	 Netflix Account \$1.00 - \$3.00
 Driver's License \$20.00	 Credit Card \$8.00 - \$22.00	 Email Address & Password \$0.70 - \$2.30
 PayPal Credentials \$1.50	 Social Security Number \$1.00	
 Medical Record from Large Scale Attack \$1.50 - \$10.00	 Complete Medical Record Up to \$1000.00	

Phishing vs. Malware



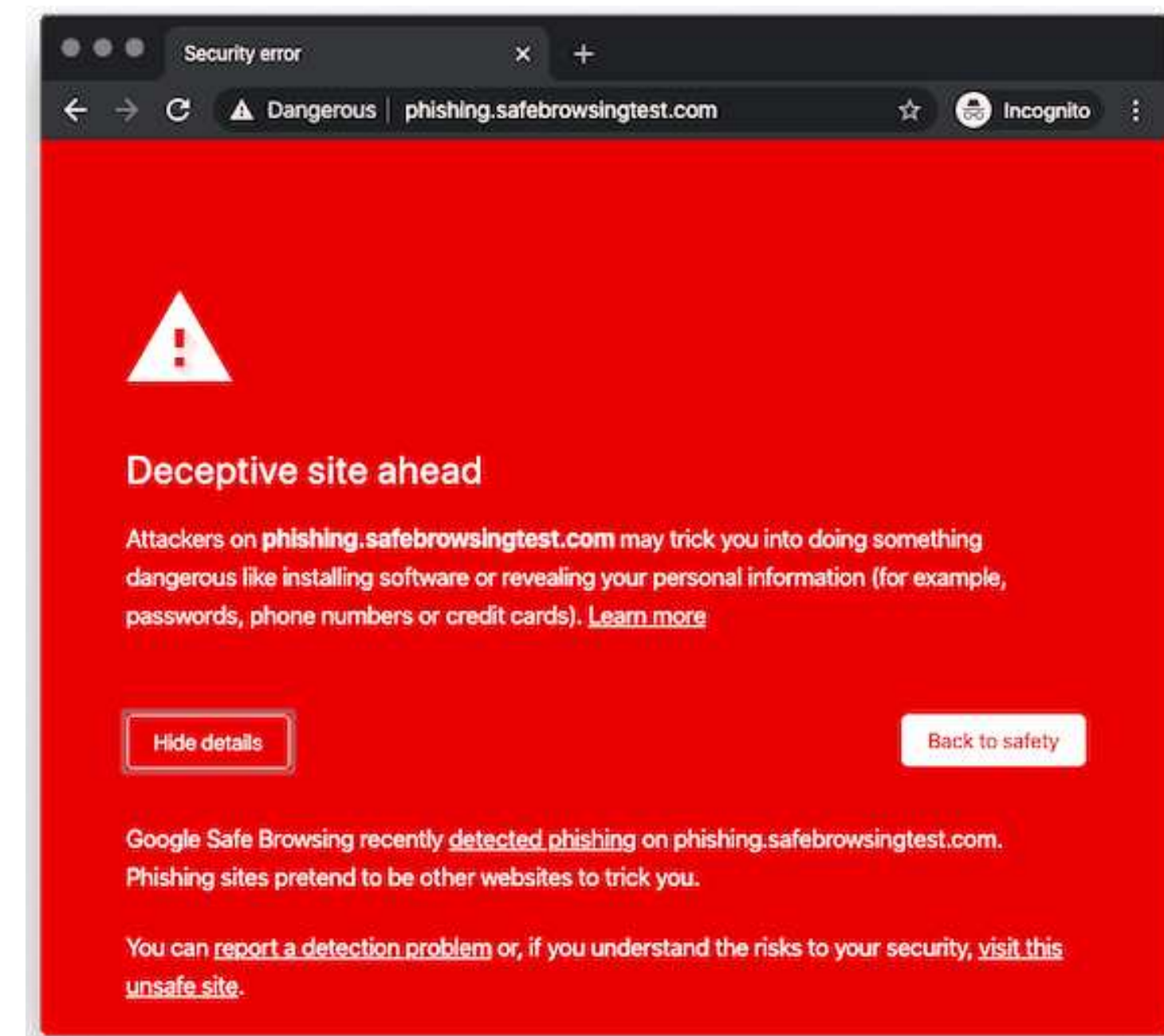
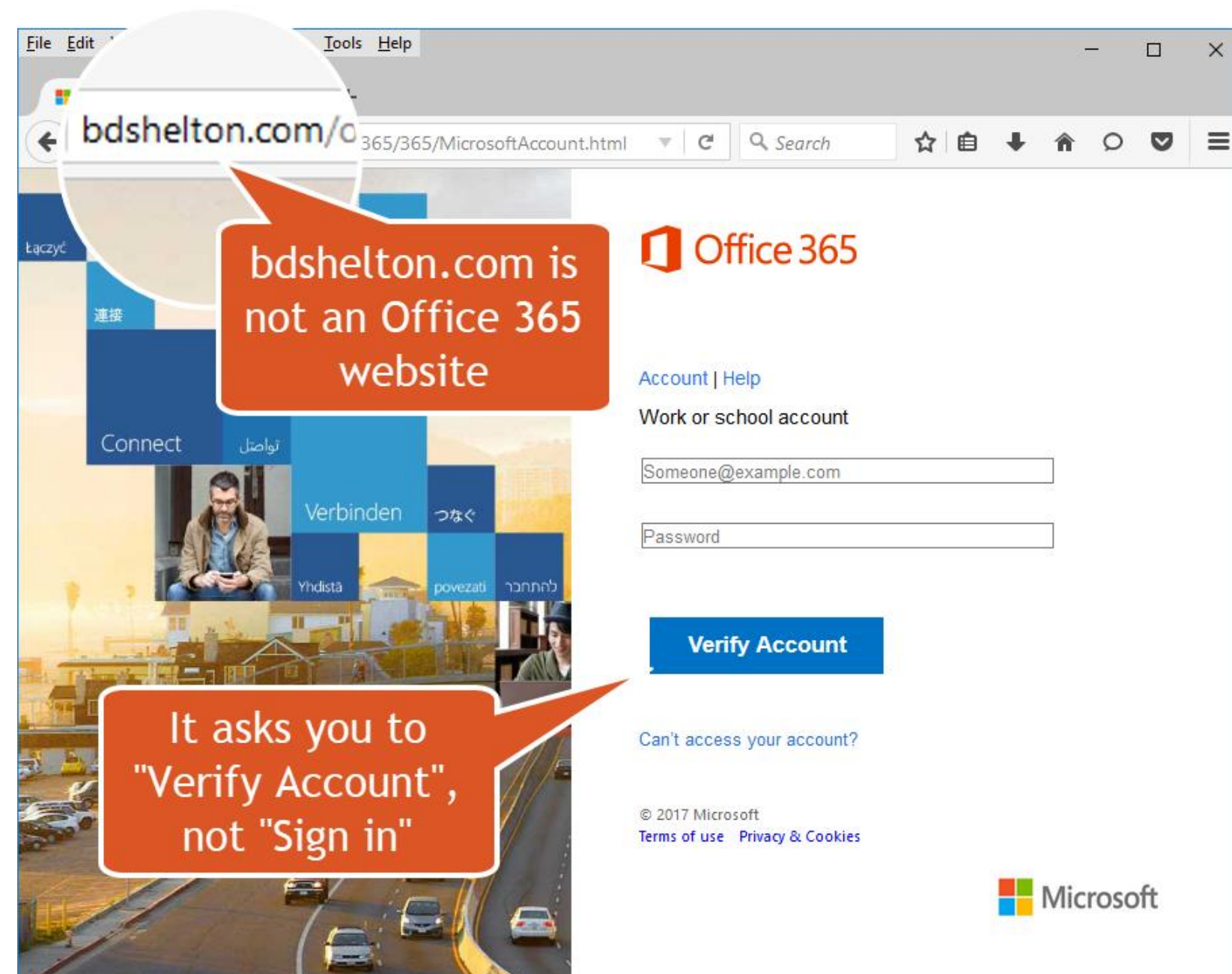
Anatomy of a Traditional Phishing Attack

- Attackers manually copy/recreate web content from target website
- Phishing content served from attacker-owned web server
 - Or a compromised web server
- Links to phishing webpages dispatched to victims through email or SMS



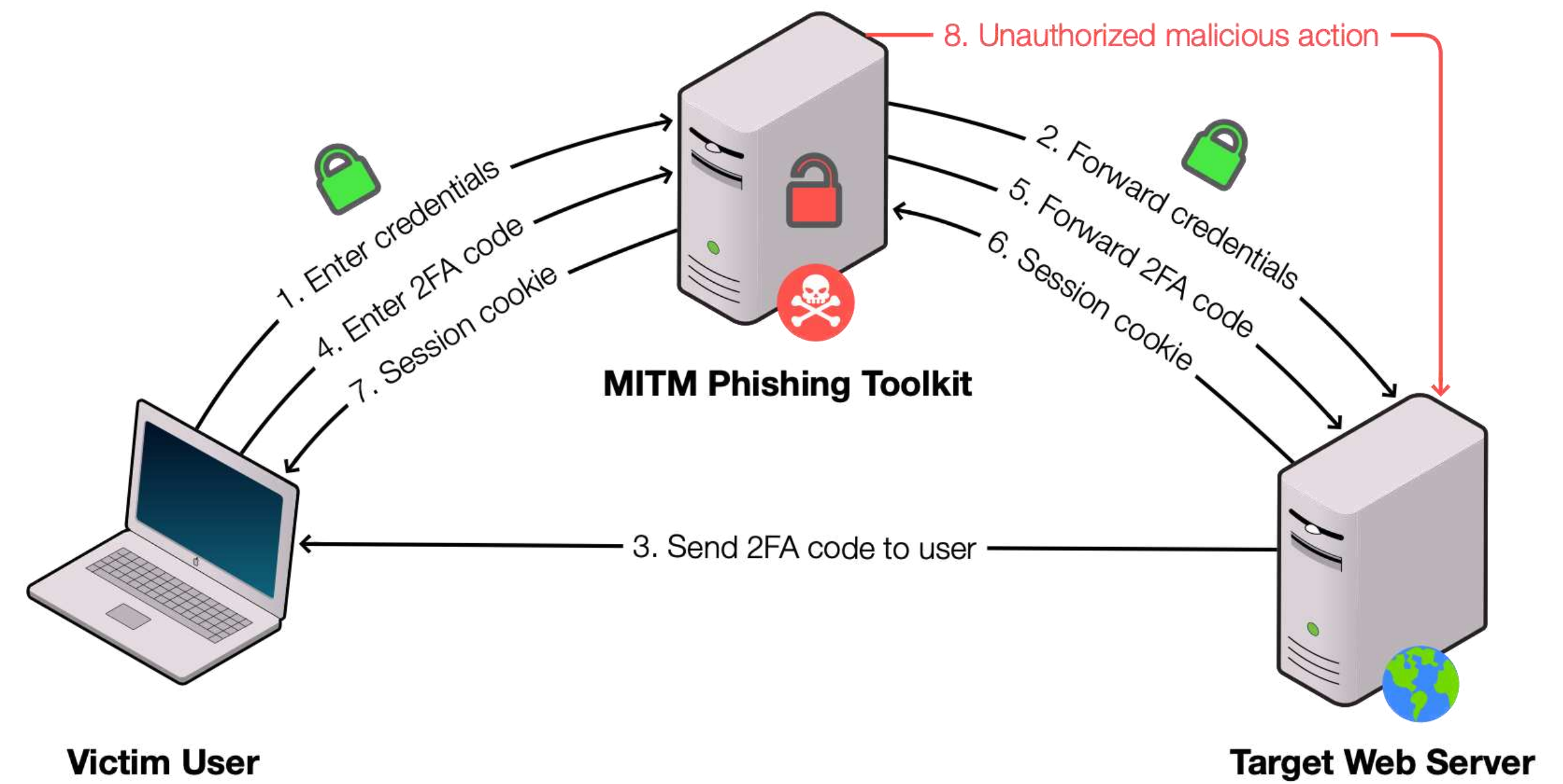
Limitations of Traditional Phishing

- Implementation errors can lead to detection
- Webpages update at increasing speeds
- Detection by anti-phishing scanners leads to immediate blocklisting



Man-in-the-Middle (MITM) Phishing Toolkits

- Malicious reverse proxy servers
 - Victims see live content from target website
 - Credentials stolen in transit
- Popular MITM phishing toolkits today:
 - Evilginx
 - Muraena
 - Modlishka



MITM Phishing Toolkit Demo

The image is a composite of two screenshots. The left screenshot shows a YouTube video player for Rick Astley's 'Never Gonna Give You Up' video. The video is playing, and the title 'Rick Astley - Never Gonna Give You Up (Video)' is visible. Below the video, there are comments and a list of merchandise. The right screenshot shows a terminal window with a dark background and red and white text. The terminal displays the output of the 'phishlet' tool, which is a phishing framework. The output includes a list of phishing kits and their status, along with a list of domains and their associated IP addresses. The terminal also shows the command 'phishlet' being executed and the resulting output.

MITM Phishing Toolkit Threat Model

- Attackers control *all* application layer content
- Cloaking restricts access to phishing content
- Detection cannot rely on integrity of application layer content

MITM Phishing Toolkit Threat Model

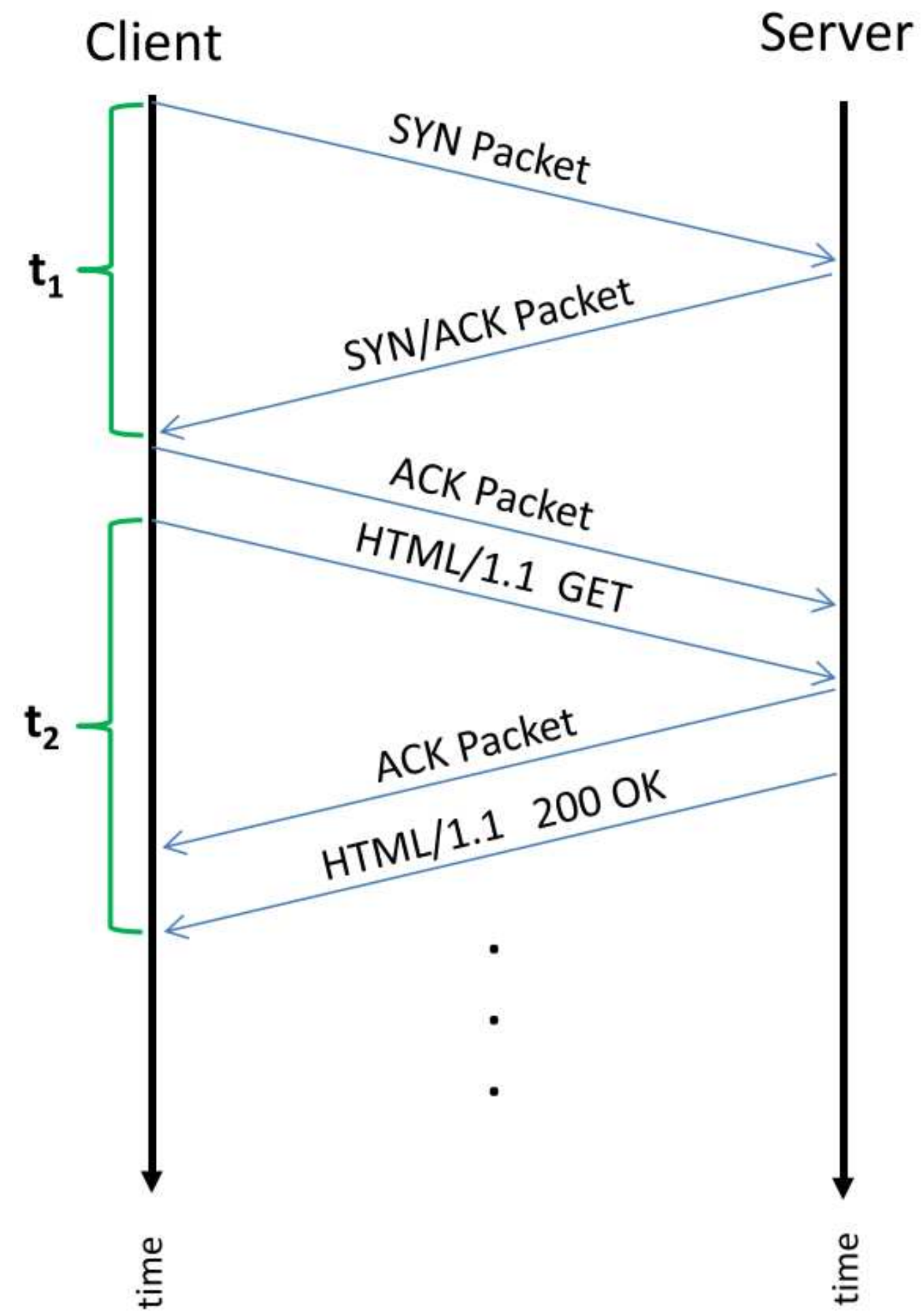
- Attackers control *all* application layer content

Fingerprint the server, not the content

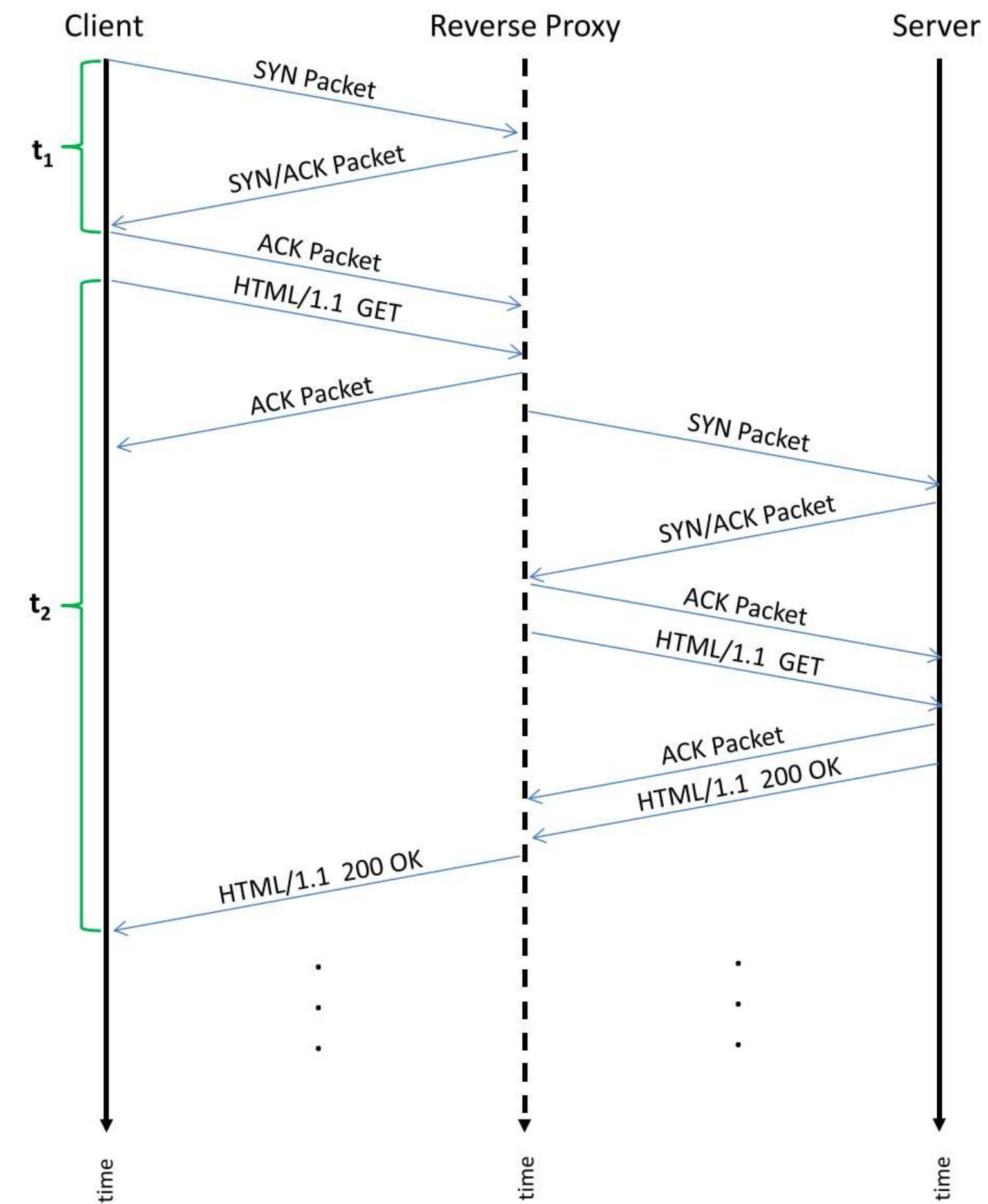
Network-Level Phishing Detection

- Network architecture can be leveraged to discover presence of toolkits
 - Network timing analysis
 - TLS fingerprinting
- Fingerprinting possible from both ends of the communication channel

Network Timing Analysis

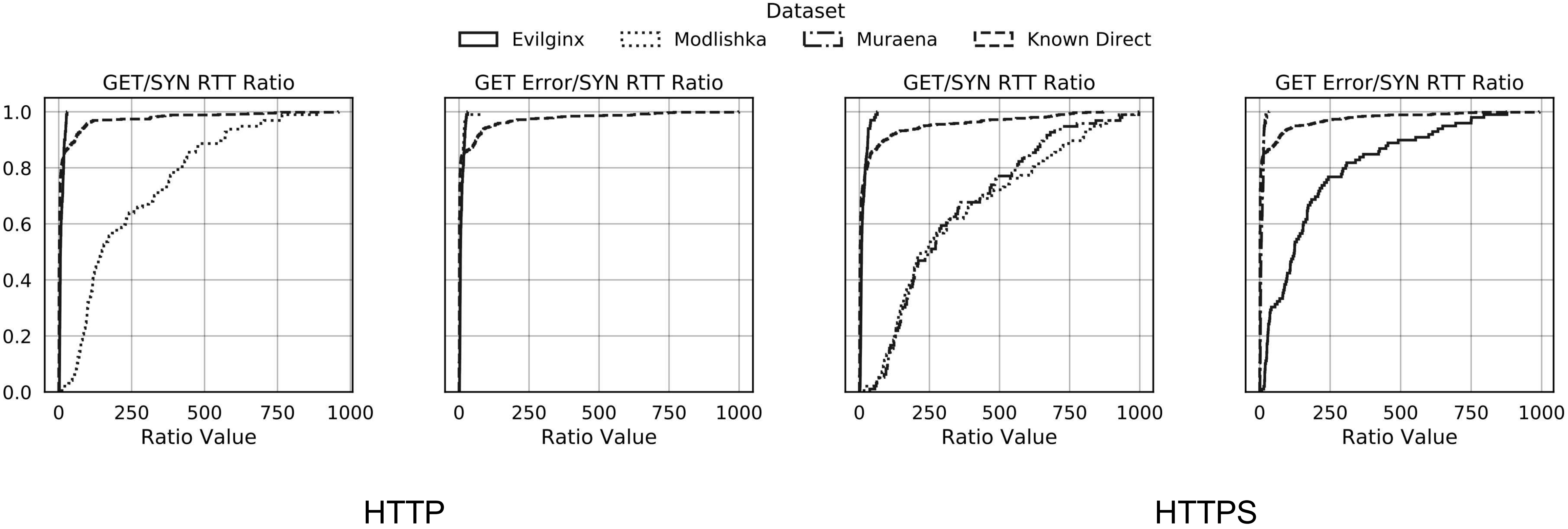


Direct Connection



Connection Through Reverse Proxy Server

Network Timing Analysis



TLS Fingerprinting

- MITM phishing toolkits utilize unusual TLS stacks
 - TLS versions supported
 - TLS libraries¹

WestpointLtd/ **tls_prober**

A tool to fingerprint SSL/TLS servers

9
Contributors

11
Issues

240
Stars

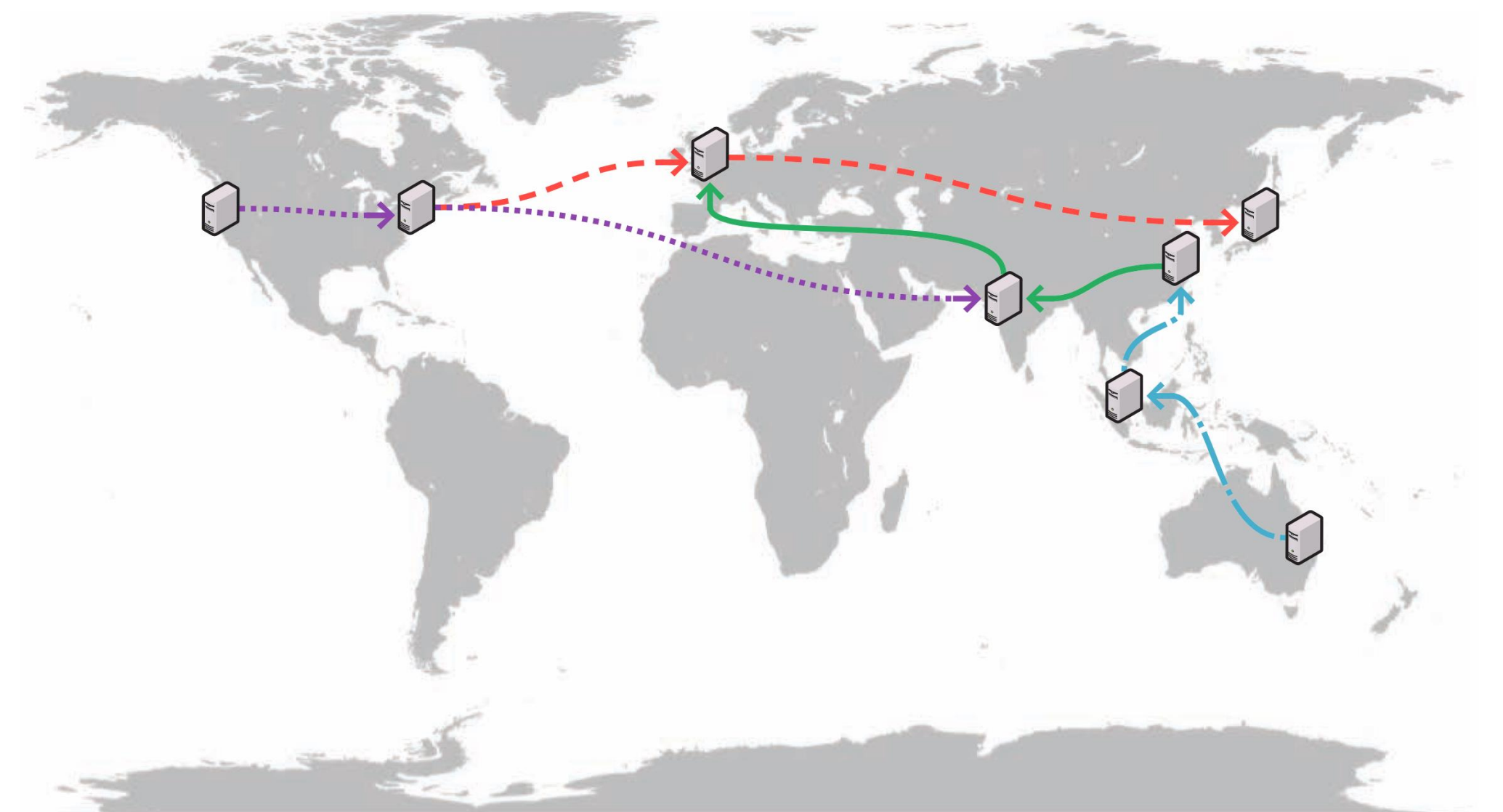
34
Forks



¹ https://github.com/WestpointLtd/tls_prober

MITM Phishing Toolkit Groundtruth

- We are the first to conduct a comprehensive study on MITM phishing toolkits
 - No groundtruth dataset on MITM phishing toolkit behavior
- Collected network-level data from 30 globally-distributed nodes
 - Recorded all permutations of client → MITM phishing toolkit → webserver
 - 146,160 data points in total
- Random forest classifier
 - Achieved **99.9%** accuracy and five-fold cross validation score of **99.9%**

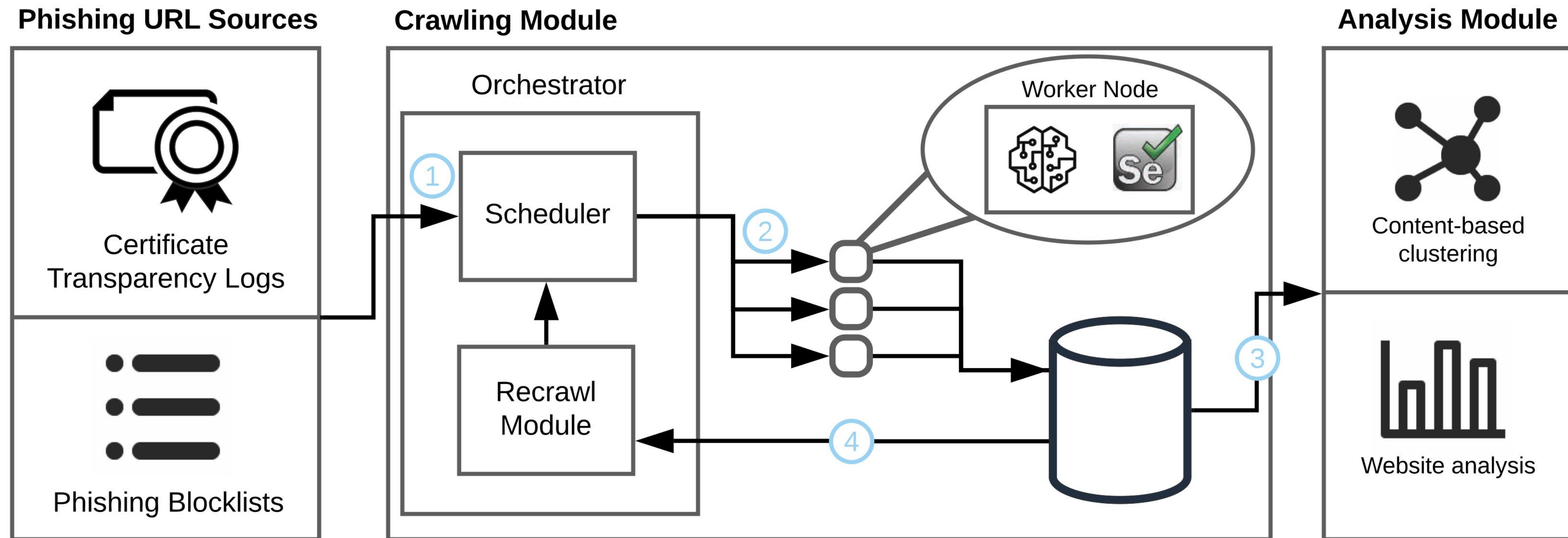


PHOCA: MITM Phishing Website Detector

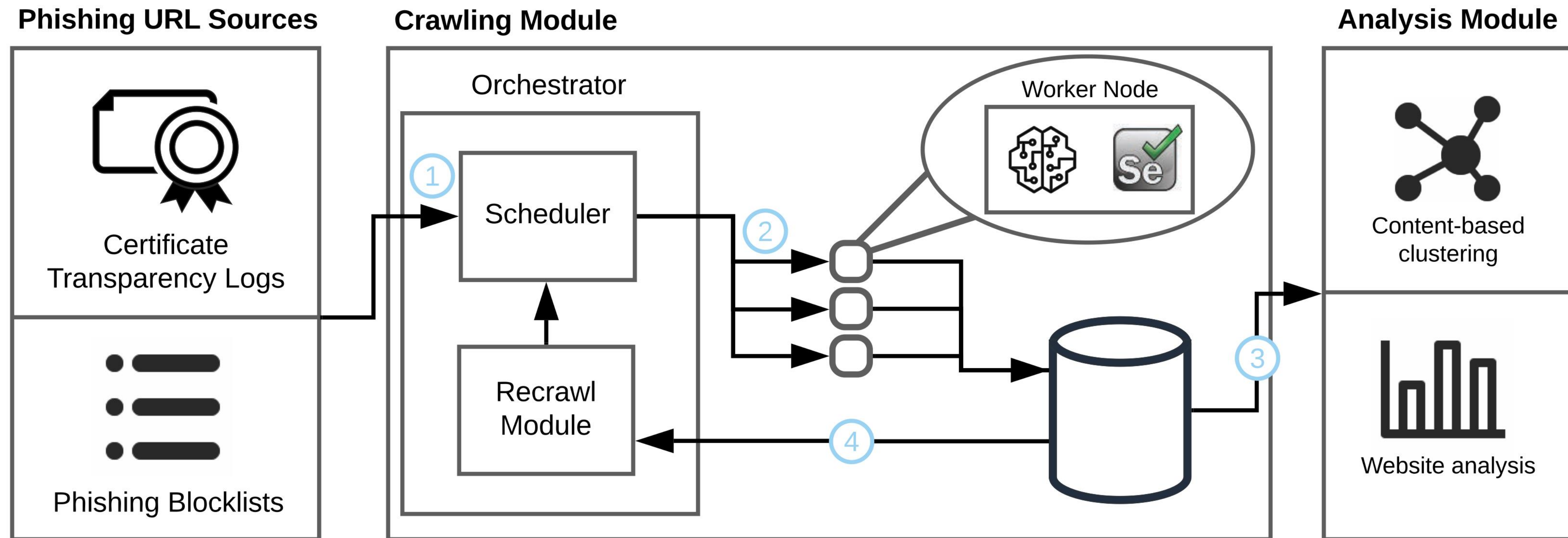
- Framework to collect network-level data on, and detect MITM phishing websites
- Named after the Latin word for seal
 - Known to use vibrations in water to detect otherwise hidden prey



Phishing Website Crawling Infrastructure

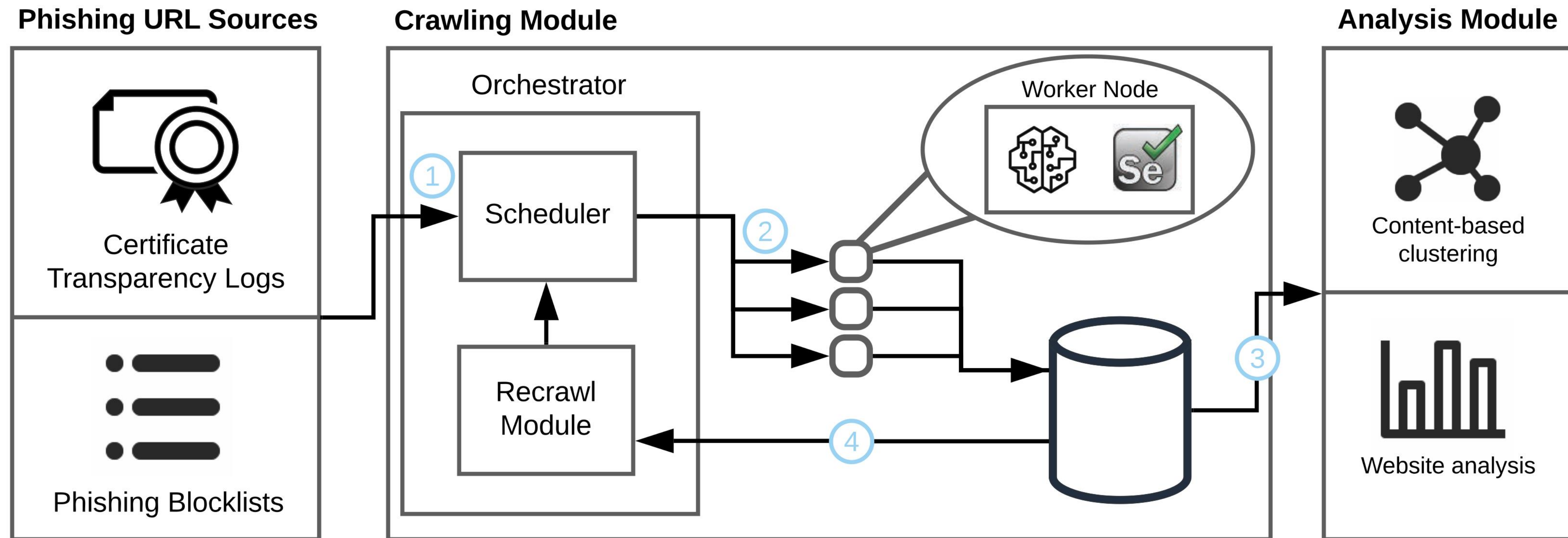


Phishing Website Crawling Infrastructure



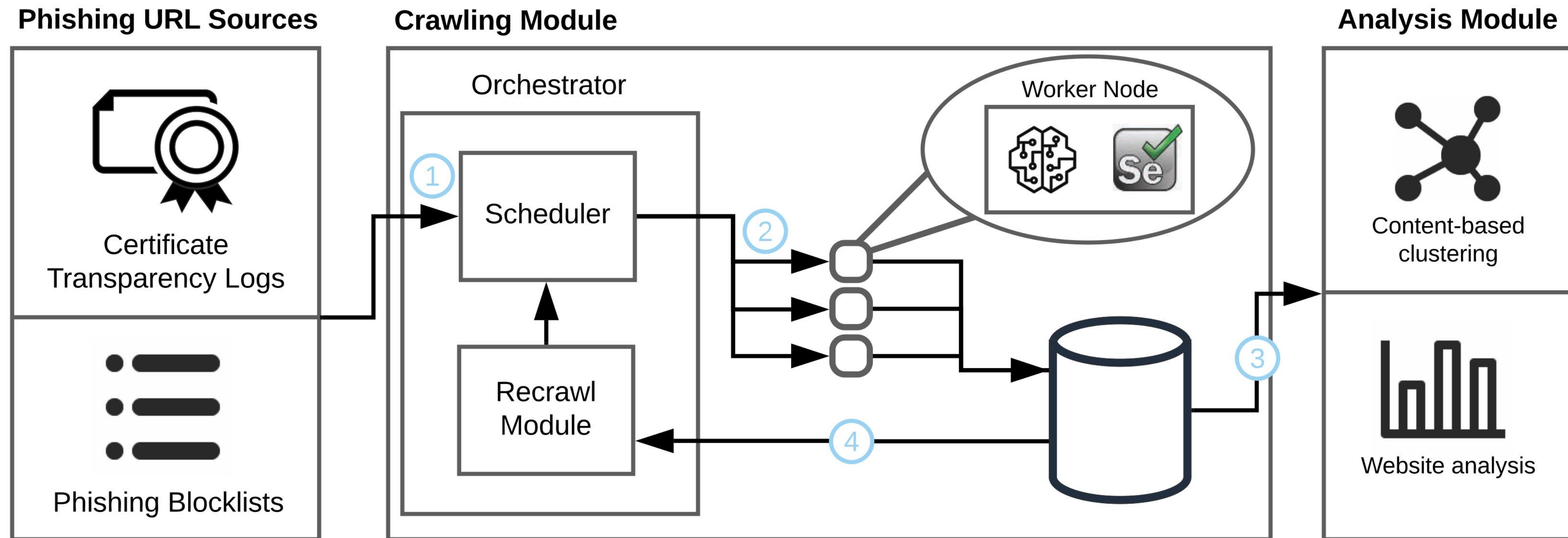
1. Candidate domains sourced from Certificate Transparency Logs and anti-phishing blocklists

Phishing Website Crawling Infrastructure



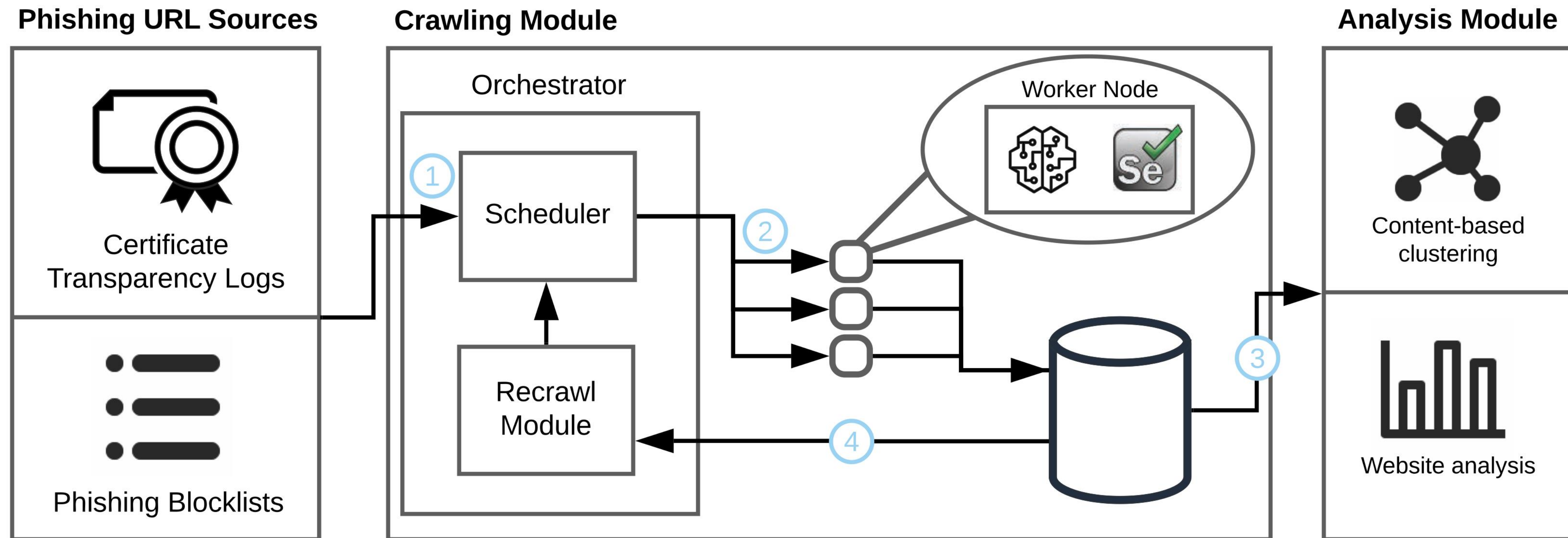
2. Scheduler module dispatches worker nodes to retrieve classification from PHOCA, and screenshot/HTML code using Selenium

Phishing Website Crawling Infrastructure



3. Collected data fed into analysis module for further processing

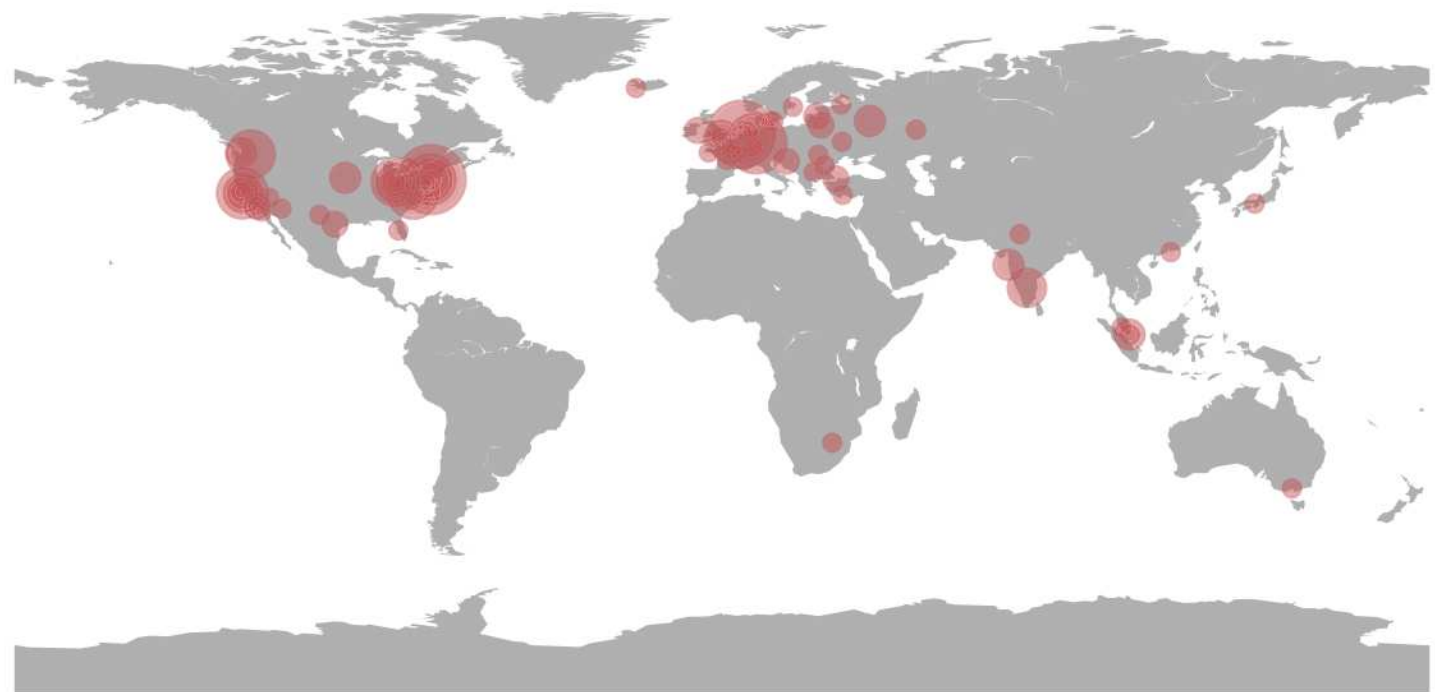
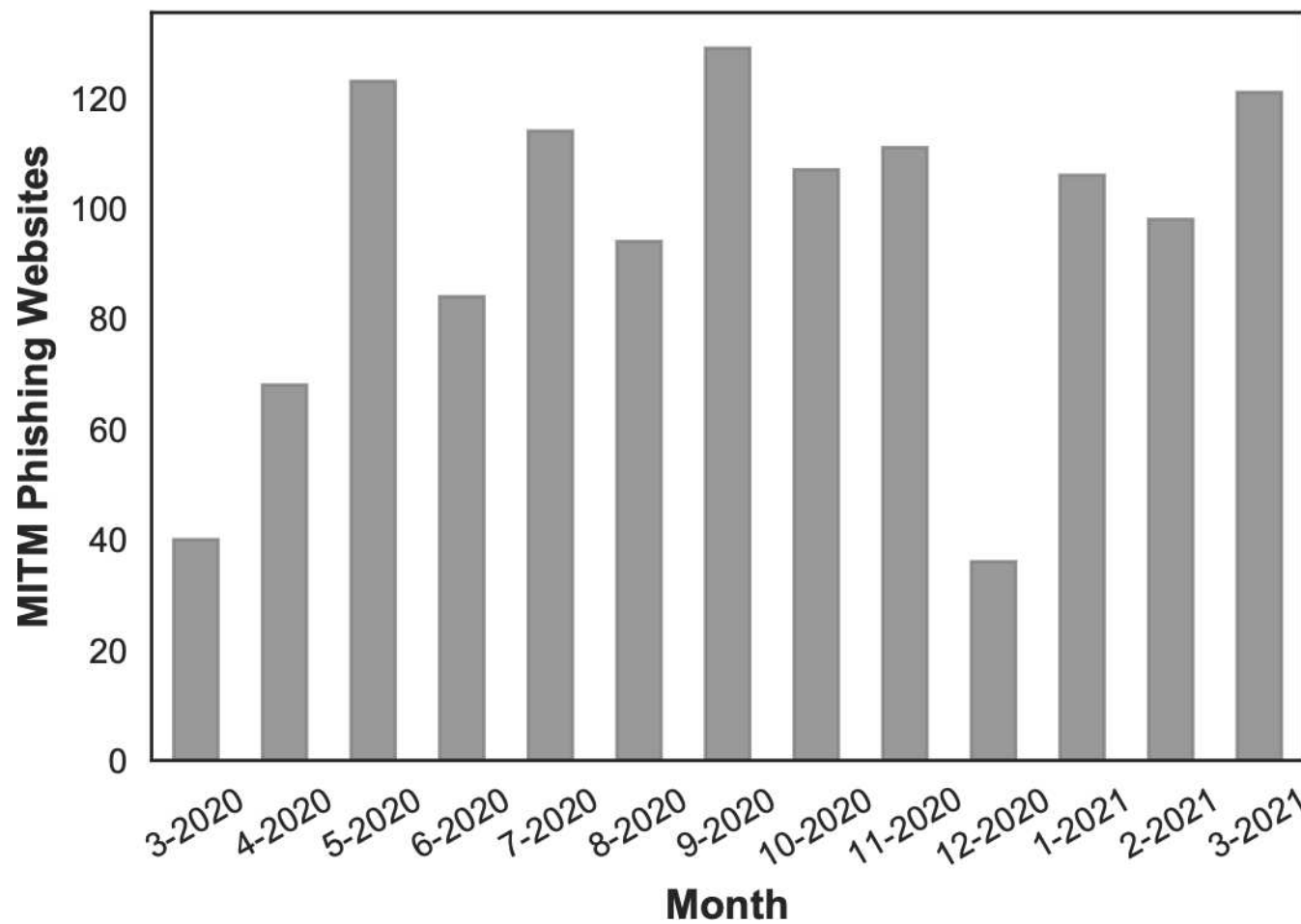
Phishing Website Crawling Infrastructure



4. Recrawling module periodically revisits websites of interest

MITM Phishing Toolkits on the Web

- Data collection period from March 25th, 2020 to March 25th, 2021
 - 841,711 web pages analyzed
 - 1,220 MITM phishing toolkits identified

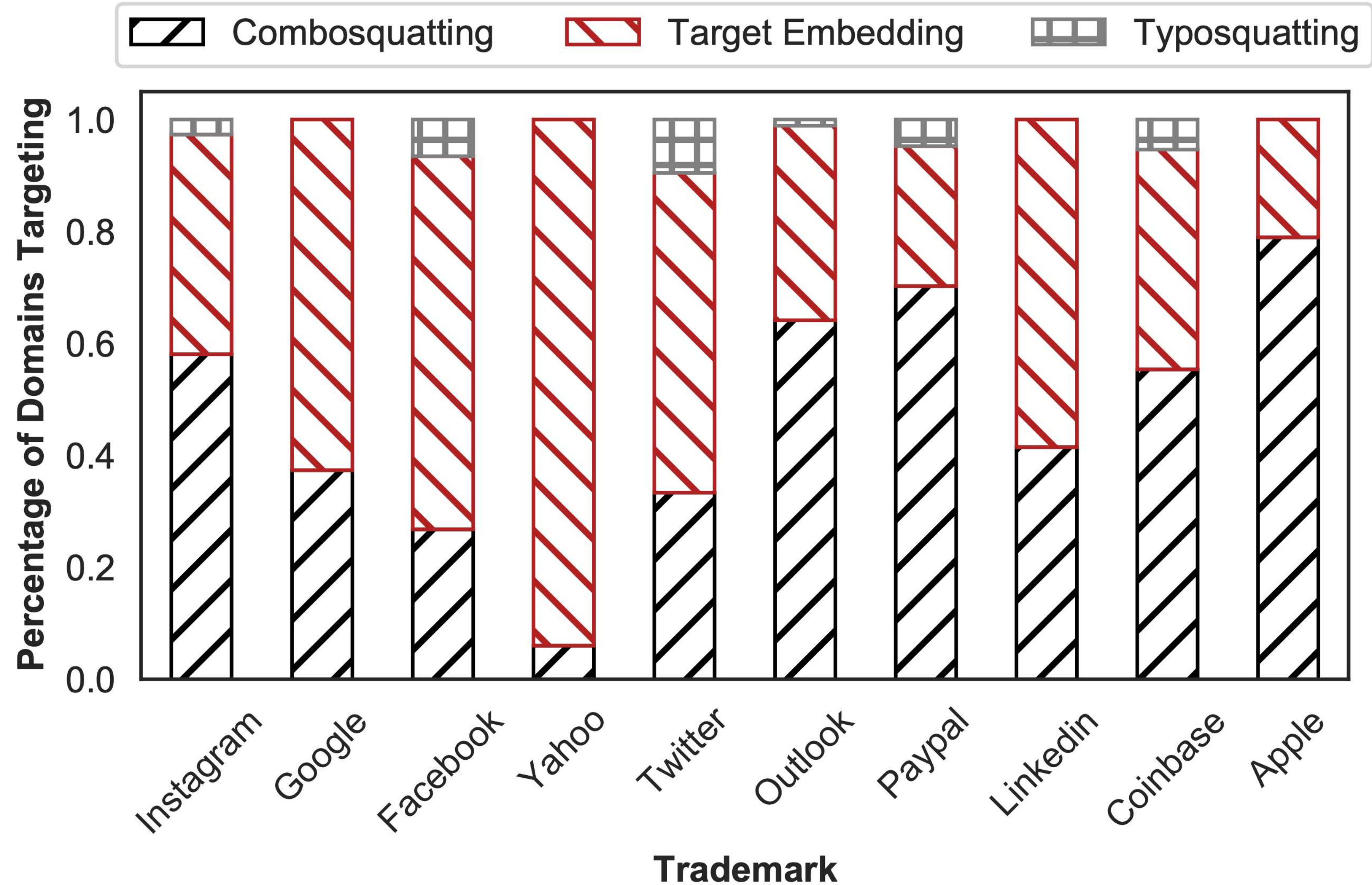


Autonomous System	IPs	Domains
Amazon.com, Inc.	162	136
DigitalOcean, LLC	160	386
Microsoft Corporation	62	165
Google LLC	37	61
Versatel Deutschland GmbH	15	1
Choopa, LLC	14	50
OVH SAS	13	38
Linode, LLC	9	40
HKT Limited	8	1
Other	150	354

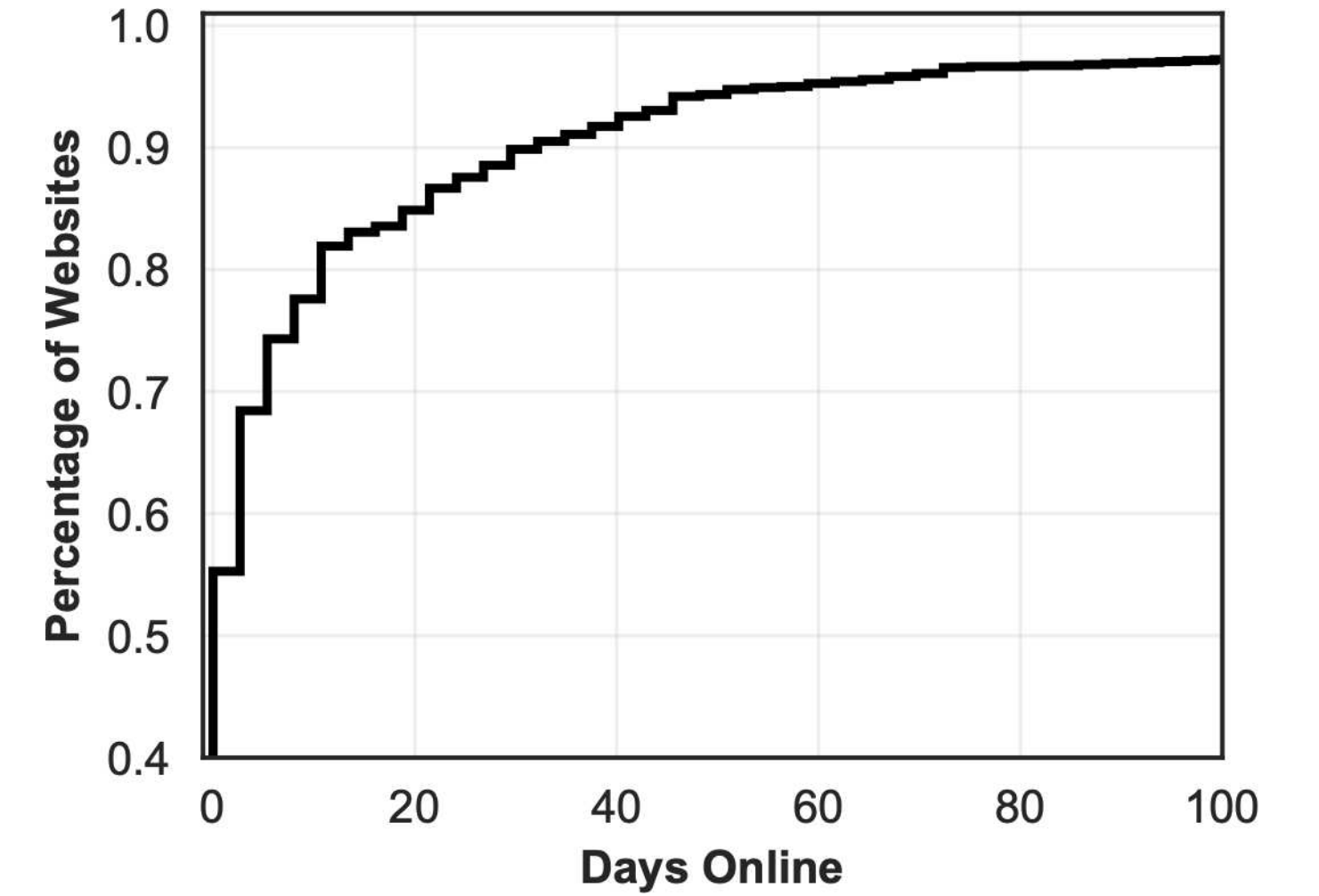
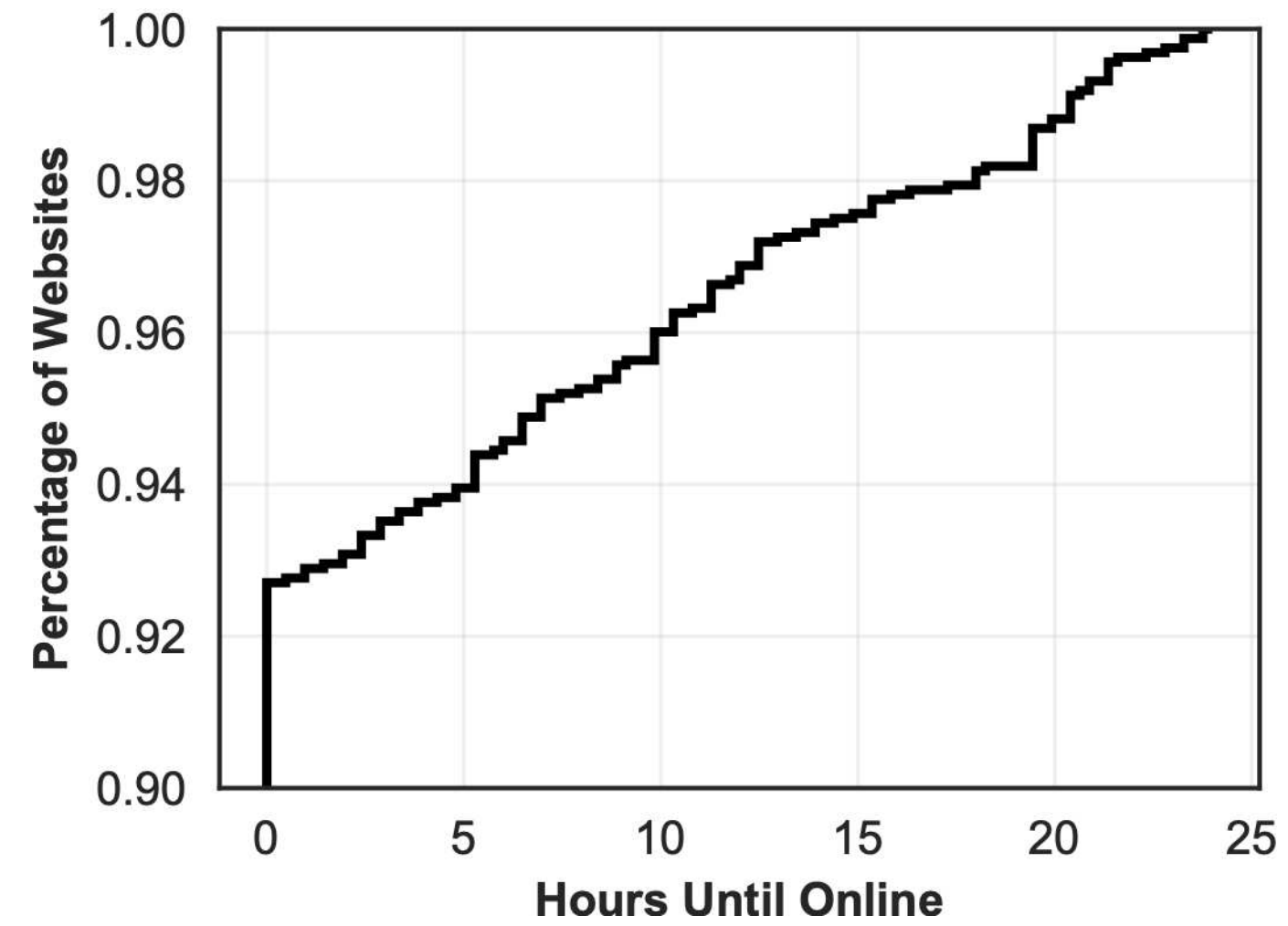
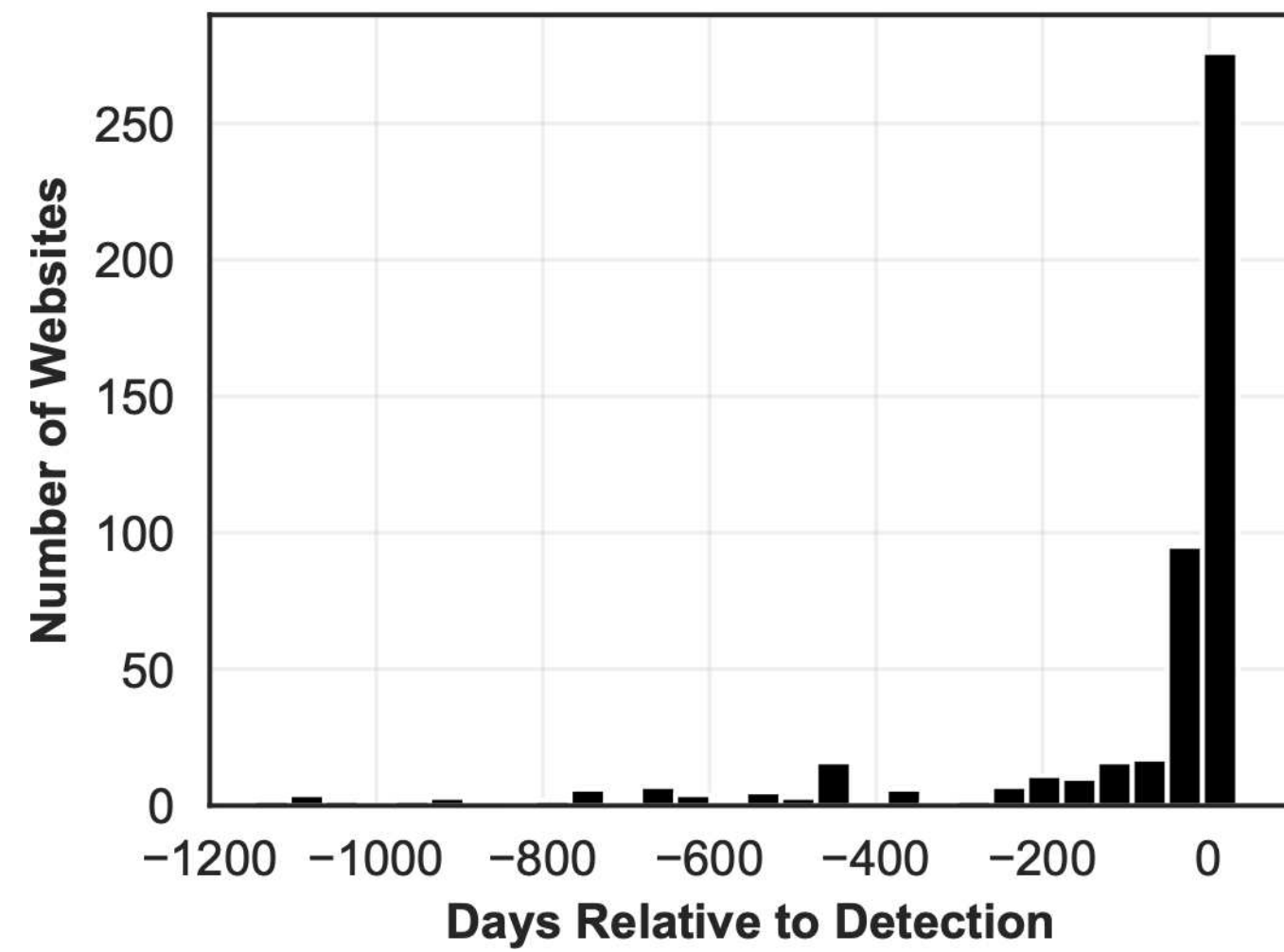
MITM Phishing Website Targets

Brand	# Websites	Example Domain
Instagram	298	<i>m.logins-instagram.ga</i>
Google	249	<i>accounts.google-2fa.com</i>
Facebook	198	<i>sign-in.facebookes.com</i>
Outlook	92	<i>login.outlooks-mail.com</i>
Paypal	84	<i>paypalsecured.com</i>
Apple	76	<i>apple.icloud.com.sssl.host</i>
Twitter	63	<i>login.mobiletwitter.tk</i>
Coinbase	56	<i>googletag.coinbasel.com</i>
Yahoo	50	<i>yahoo.com.msg-inbox.ga</i>
Linkedin	41	<i>linkedin.com.securelogin.xyz</i>

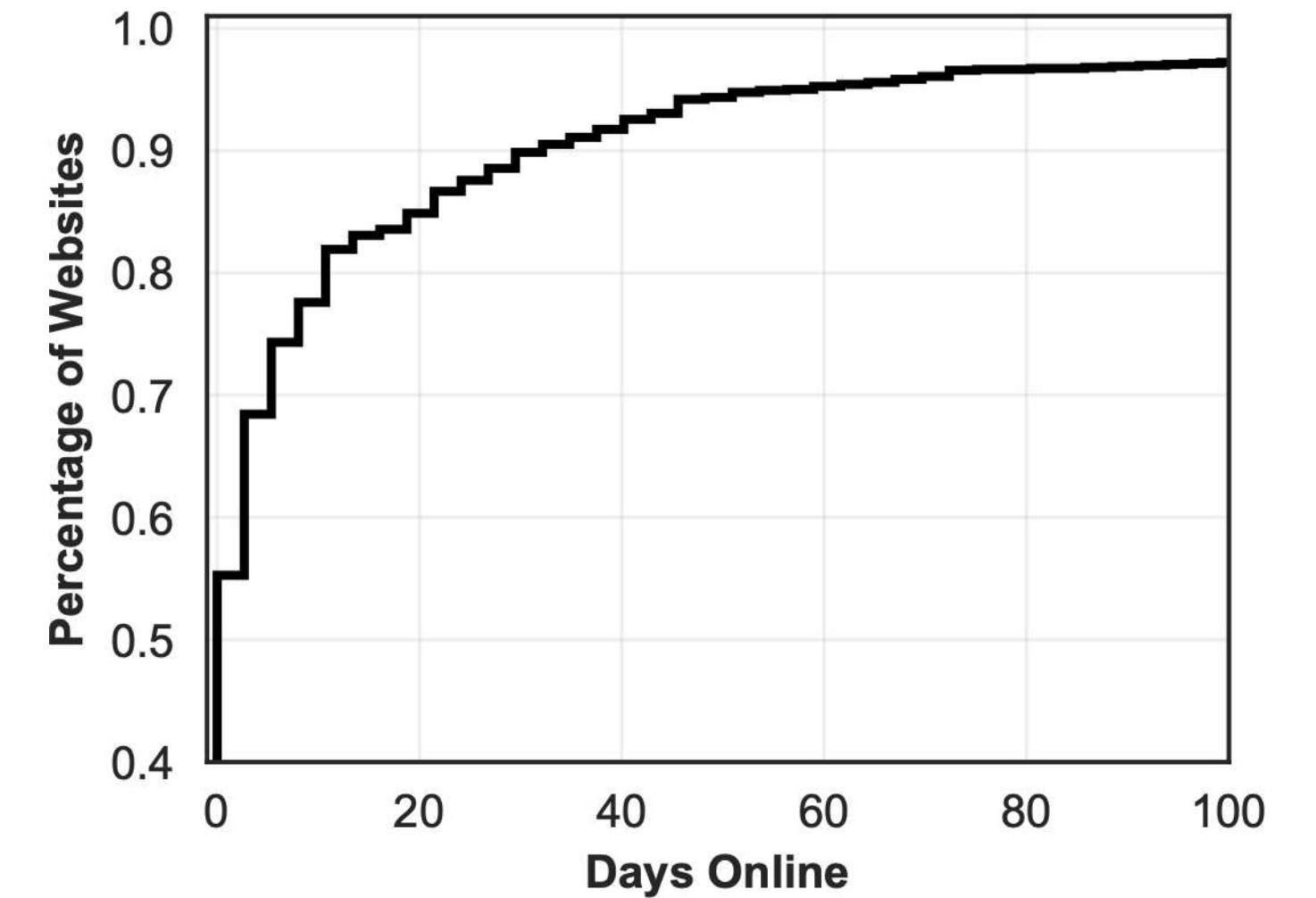
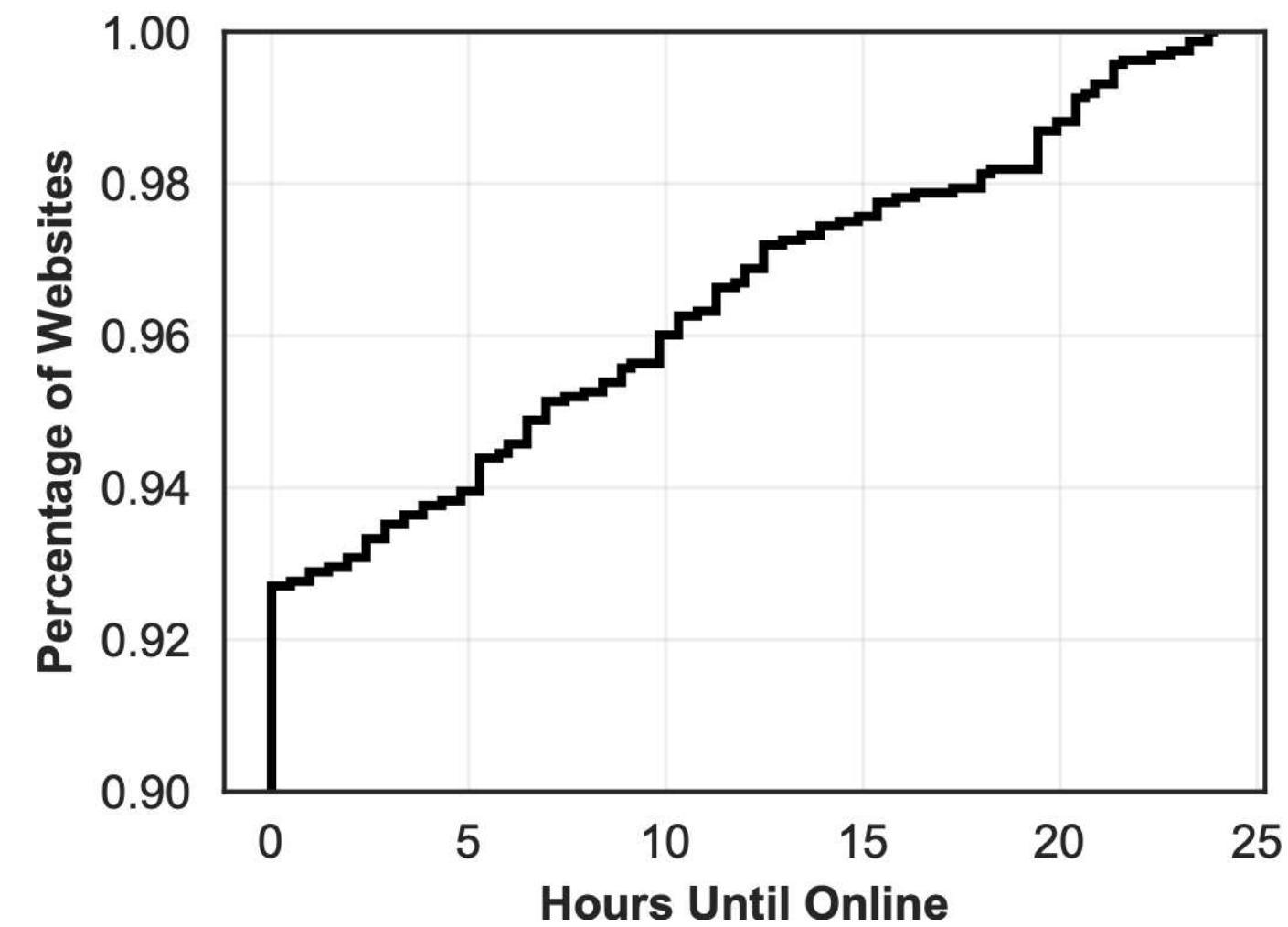
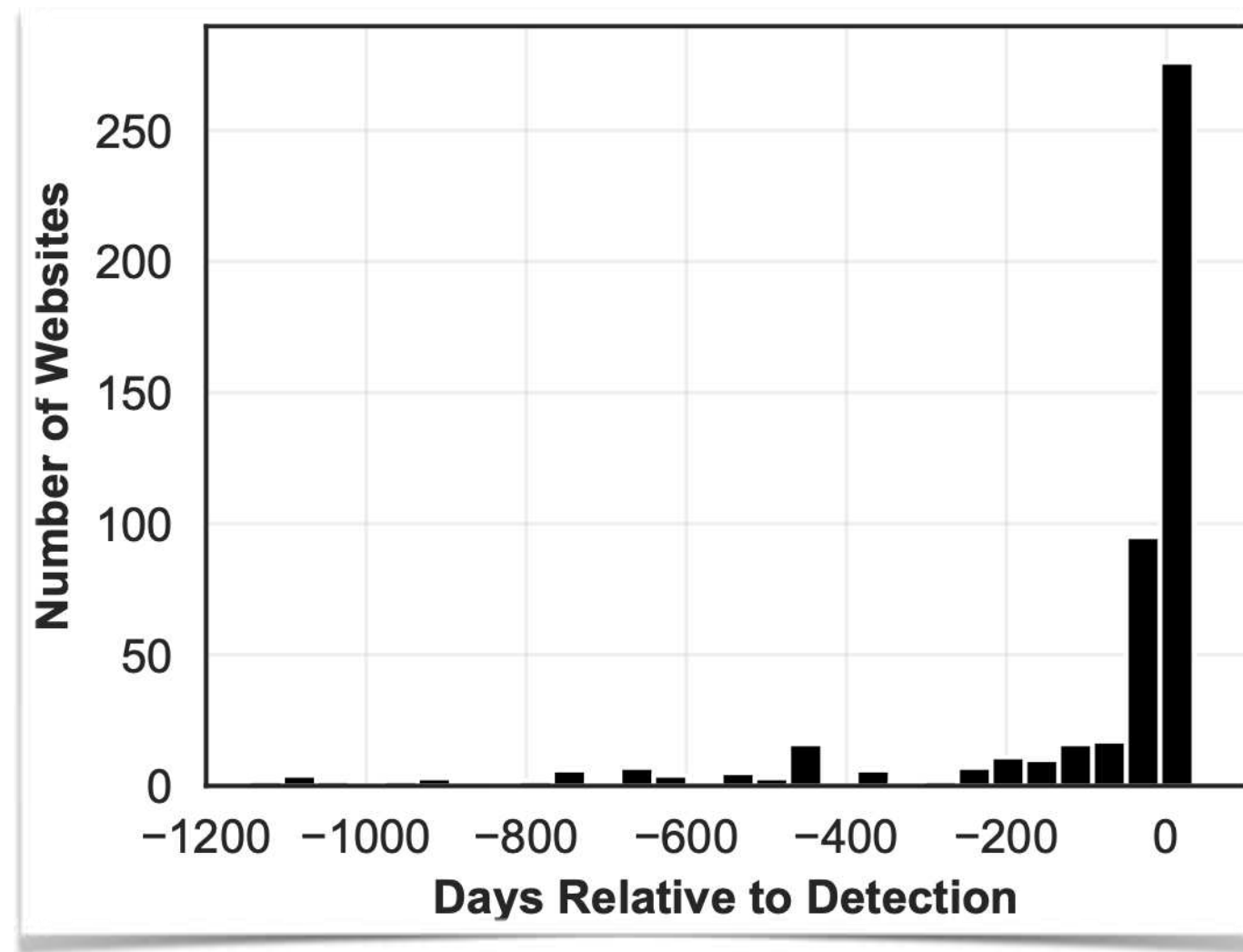
MITM Phishing Domain Types



MITM Phishing Website Lifecycle

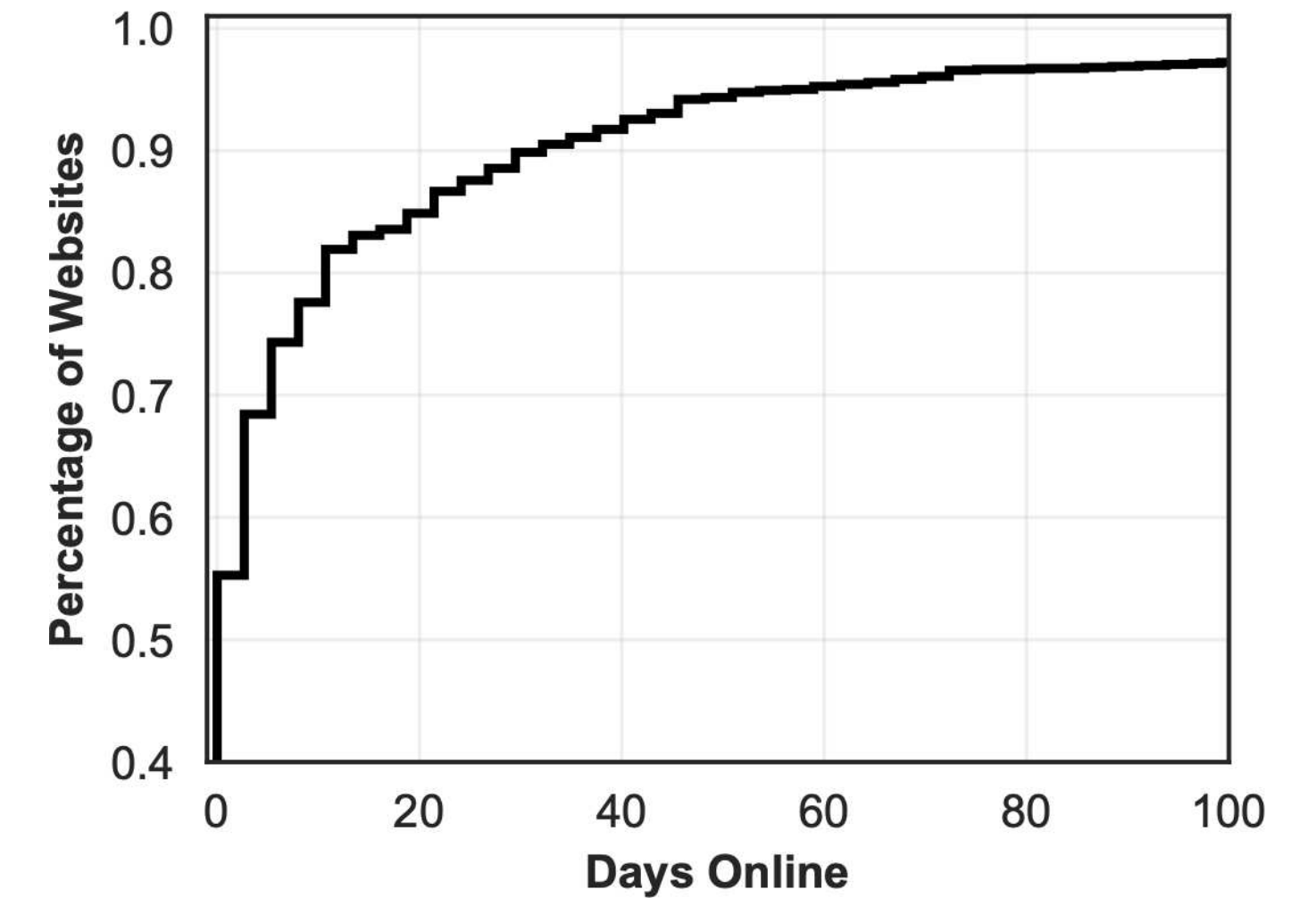
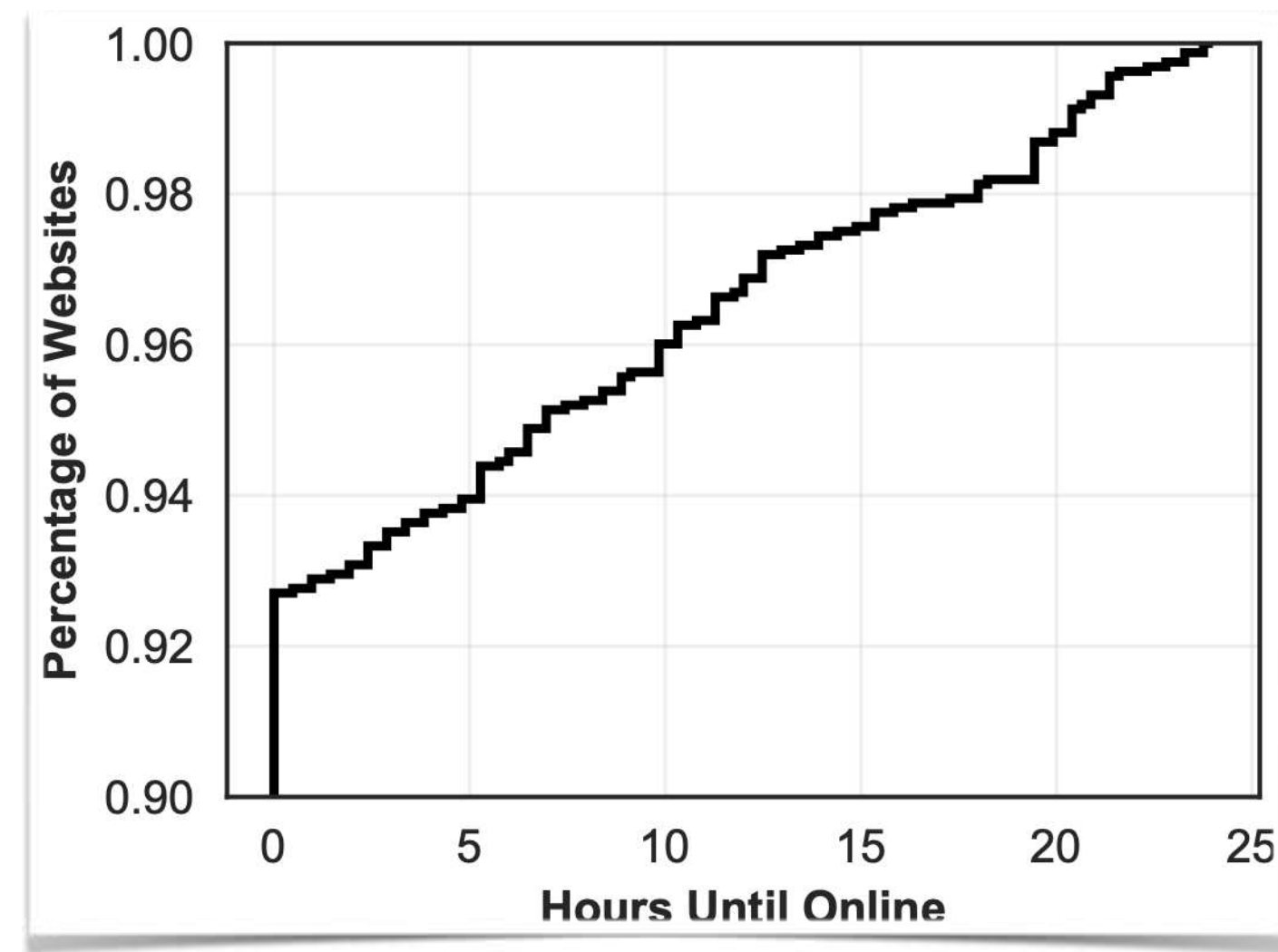
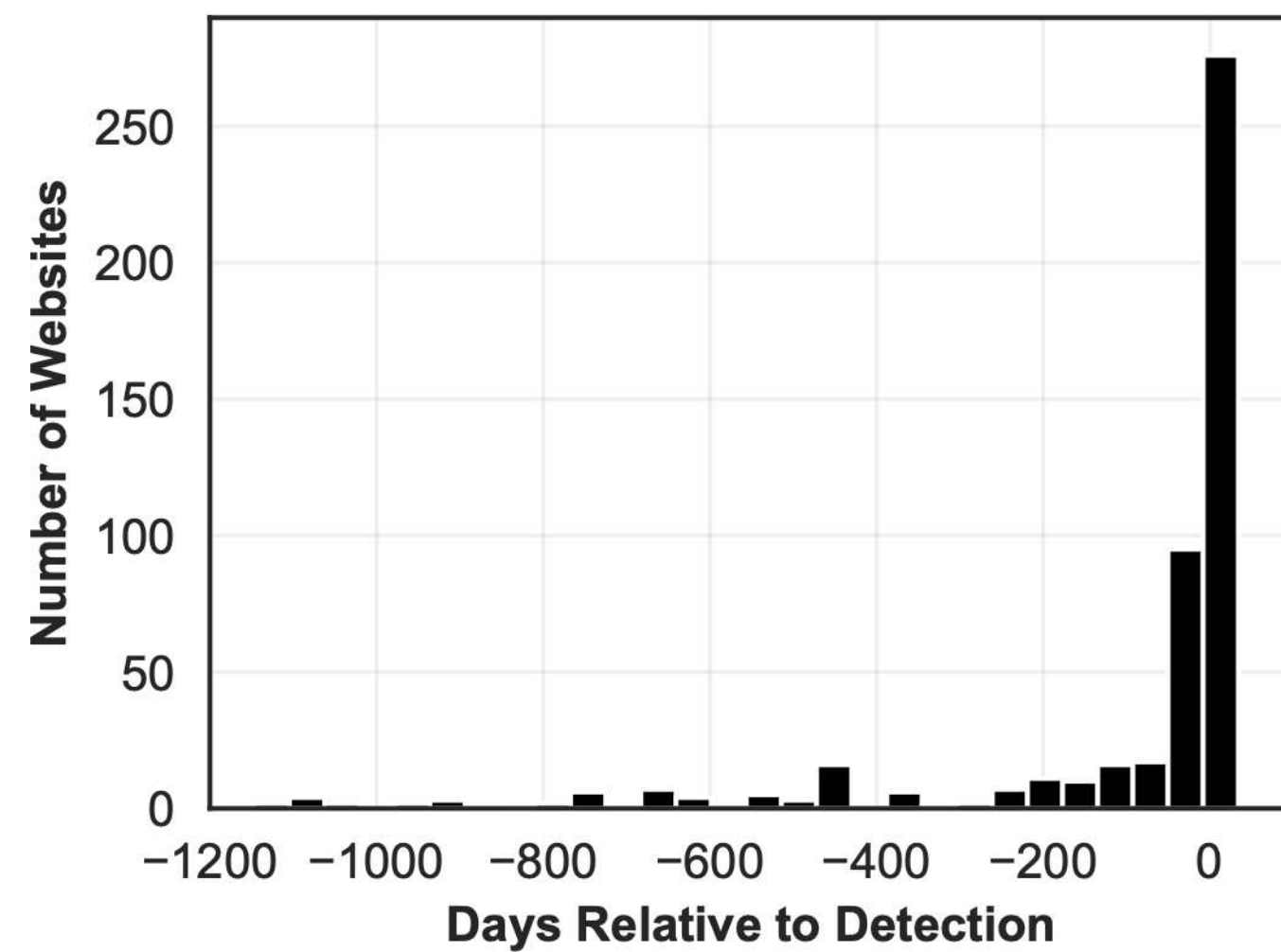


MITM Phishing Website Lifecycle



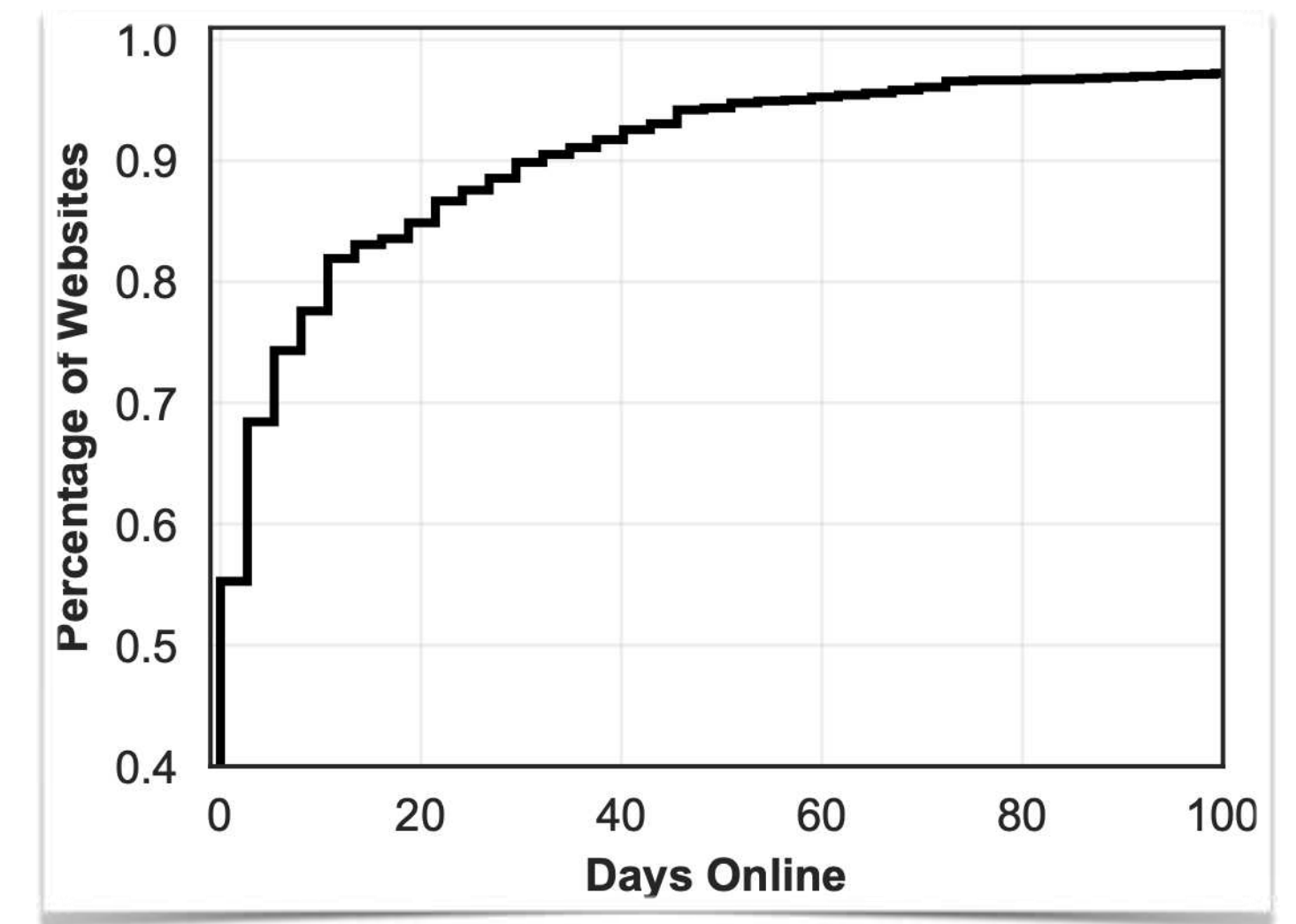
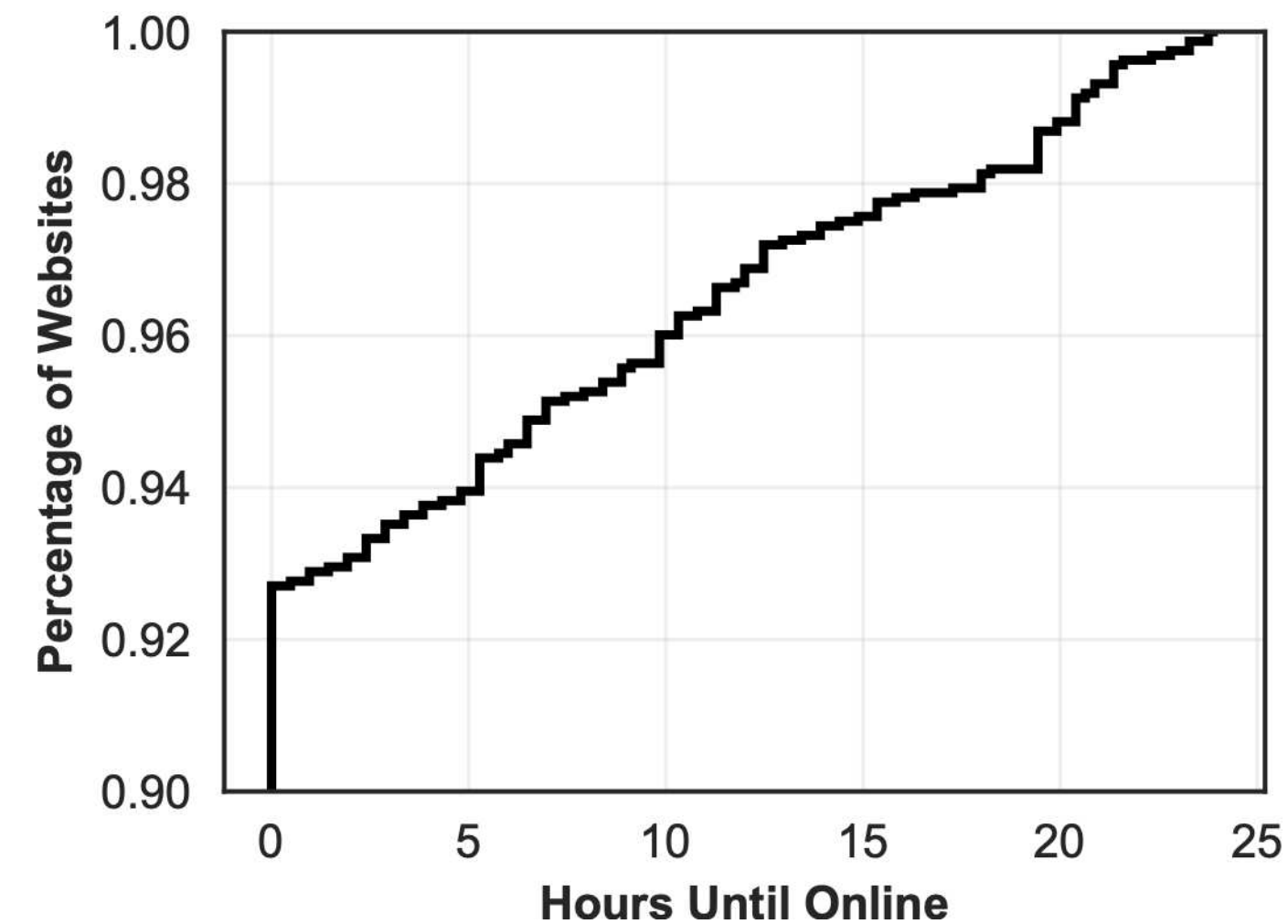
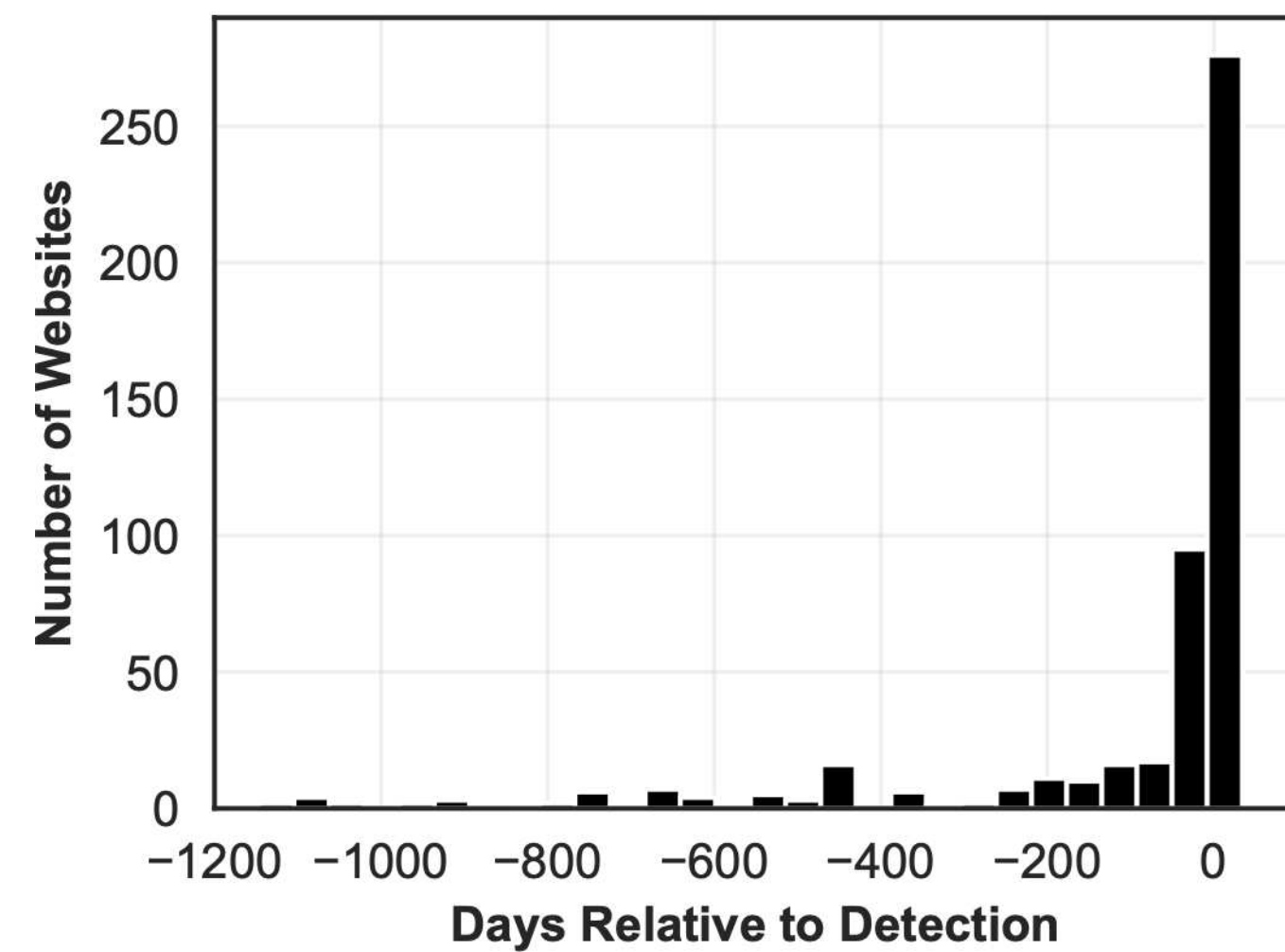
MITM phishing use freshly registered domains

MITM Phishing Website Lifecycle



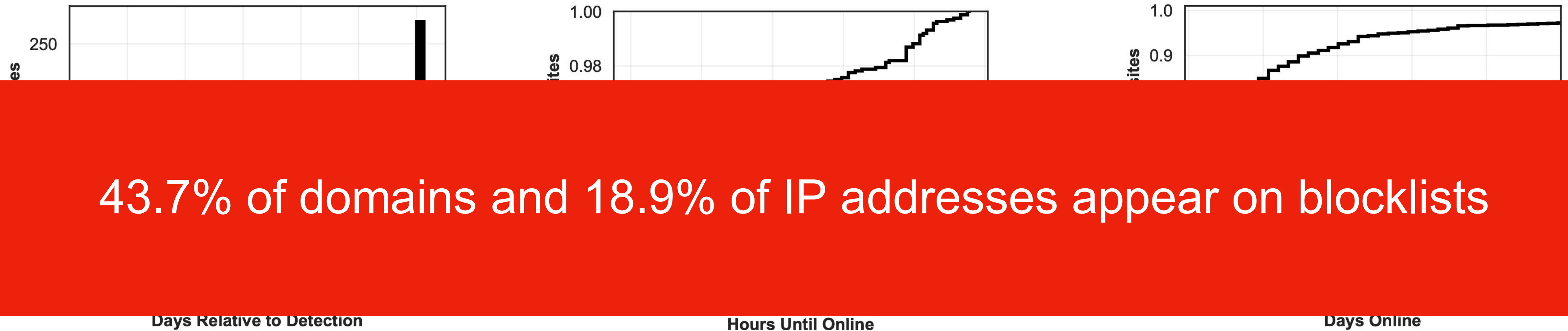
MITM phishing websites are weaponized immediately after TLS certificate creation

MITM Phishing Website Lifecycle



20% of MITM phishing websites remain active for longer than 10 days

MITM Phishing Website Lifecycle



Case Study: Palo Alto Networks

- 56.7% of MITM phishing domains labeled as malicious by PAN in-line scanners
 - 15.1% received label at least one week after our initial discovery
- 6,403 customer requests directed towards 260 phishing websites over six months
 - Originating from 368 distinct firewall devices



Server-side TLS Fingerprinting

- MITM phishing toolkits do not utilize common web client TLS stacks
 - Forwarded HTTP User-Agent strings do not match TLS fingerprints
- JA3 TLS fingerprinting¹ utilized to identify unique TLS implementations
- Purchased 13,000 advertising impressions from a popular advertising service
 - Collected 163 unique TLS fingerprints from 4,311 distinct HTTP User-Agents
- TLS fingerprints of MITM phishing toolkits unique in this dataset



¹ <https://github.com/salesforce/ja3>

Countermeasures

- Users:
 - Analyze the primary domain of any suspicious URL encountered
 - Use U2F to secure online accounts
- Online Services/Anti-phishing Entities:
 - Look for discrepancies in client TLS fingerprints
 - Utilize network-level detection techniques when searching for phishing websites



Conclusion

- MITM phishing toolkits allow attackers to launch highly effective phishing attacks
- Unique architecture allows for fingerprinting at the network layer
- We found 1,220 MITM phishing toolkits operating in the wild, targeting real users
- Anti-phishing ecosystem does not effectively capture MITM phishing toolkits

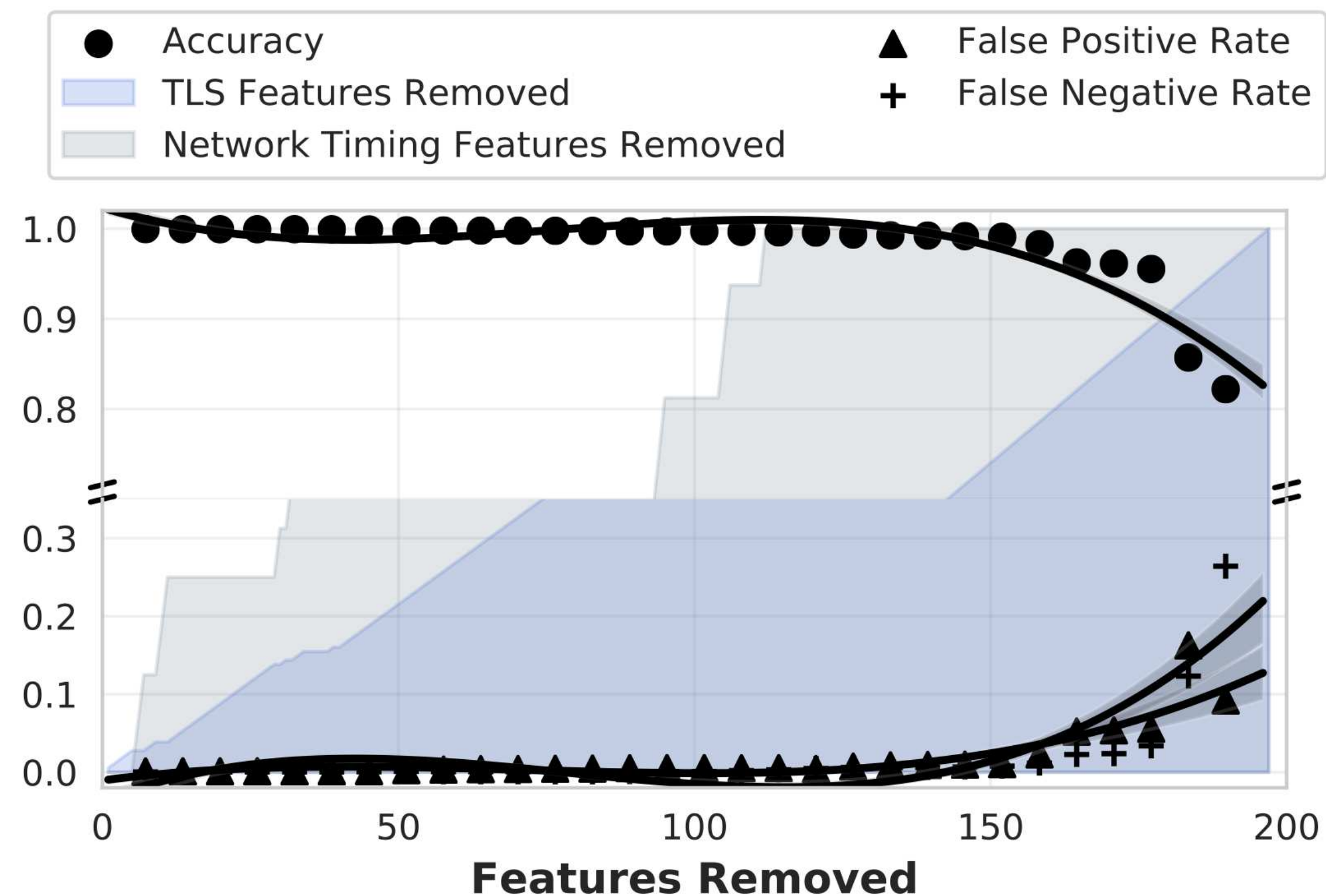
Code and data: <https://catching-transparent-phish.github.io>

Thank you for your time! Any questions?

BACKUP SLIDES

MITM Phishing Toolkit Classifier

- Trained random forest classifier on data from real websites and MITM phishing toolkits
- Achieved **99.9%** accuracy and five-fold cross validation score of **99.9%**



PHOCA Demo

```
ubuntu@ip-172-26-11-7: ~/2FAPhishingDetector
ubuntu@ip-172-26-11-7:~/2FAPhishingDetector$ sudo ./detector www.google.com
www.google.com is not a 2FA phishing website with 99.00% confidence
ubuntu@ip-172-26-11-7:~/2FAPhishingDetector$ sudo ./detector www.amazon.com
www.amazon.com is not a 2FA phishing website with 100.00% confidence
ubuntu@ip-172-26-11-7:~/2FAPhishingDetector$ sudo ./detector www.instagram.com
www.instagram.com is not a 2FA phishing website with 94.00% confidence
ubuntu@ip-172-26-11-7:~/2FAPhishingDetector$ sudo ./detector demo.catching-transparent-phish.tech
demo.catching-transparent-phish.tech is a 2FA phishing website with 98.00% confidence
ubuntu@ip-172-26-11-7:~/2FAPhishingDetector$
```

Here, our classifier correctly identifies our deployment of Evilginx as a 2FA phishing website. Lastly, let's classify a real-world deployment of Evilginx we found during this study